UPGRADING OF EXISTING DCS SYSTEMS & ASSOCIATED EQUIPMENT FOR CYBER SECURITY COMPLIANCE AT RMP CCR & OMCCR IN MAA REFINERY CA/CPC/0707

FUNCTIONAL DESIGN SPECIFICATION FOR APPLIED CYBERSECURITY CONTROLS AT RMP

KUWAIT NATIONAL PETROLEUM COMPANY

D	Re-Issued for Approval	JV	MA	MS	13-Aug-2025
C	Re-Issued for Approval	JV	MA	MS	29-May-2025
B	Re-Issued for Approval	JV	MA	MS	17-April-2025
A	Issued for Approval	JV	MA	MS	18-Feb-2025
Rev.	**Description**	**Prepared**	**Checked**	**Approved**	**Date**

General

Rev	Status	Description	Date	Prepared	Reviewed	Approved
A	For Approval	Issued for approval	18-Feb-2025	Jaiyaganesh Veeraraghavan	Mokhtar Abdelghaffar	Mohammad Salim
B	For Approval	Re-Issued for approval	17-Apr-2025	Jaiyaganesh Veeraraghavan	Mokhtar Abdelghaffar	Mohammad Salim
C	For Approval	Re-Issued for approval	29-May-2025	Jaiyaganesh Veeraraghavan	Mokhtar Abdelghaffar	Mohammad Salim
D	For Approval	Re-Issued for approval	13-Aug-2025	Jaiyaganesh Veeraraghavan	Mokhtar Abdelghaffar	Mohammad Salim

General

Contents

1 INTRODUCTION 9

1.1 Introduction and Overview 9

1.2 Document Purpose 10

1.3 Project Information 10

1.4 Objective 10

1.5 Reference Documents 11

1.5.1 International Electrotechnical Commission 11

1.5.2 HOLD 11

1.6 Abbreviations 12

2 SCOPE OVERVIEW 18

3 SYSTEMS UNDER CONSIDERATION 20

4 HARDWARE OVERVIEW 21

4.1 Cybersecurity Servers: 21

4.2 L3 DCS PIN/CS Switches 22

4.3 L3 Firewall 26

4.4 L1 Firewall 26

5 SOFTWARE OVERVIEW 28

5.1 List of Software 28

5.2 List of Licenses 29

6 CYBERSECURITY HARDWARE SPECIFICATIONS 30

6.1 Server Hardware Specification 30

6.1.1 V95 Server Specification 30

6.1.2 HPE Backup Server Specification 31

6.2 L3 Network Switches Hardware Specification 32

6.2.1 RH102BG 48-Gigabit SFP Managed Switch 32

6.2.2 RH102BM 24-Gigabit 10/100/1000 Base-Tx Managed Switch 32

6.3 Firewall Hardware Specification 33

6.3.1 FortiGate-401F 33

6.3.2 Third-Party Interface Firewalls 34

6.3.2.1 ConneXium 34

7 WINDOWS MACHINES HARDENING BASELINE 35
7.1 V95 Server BIOS Hardening Parameters 35
7.2 H94 Server BIOS Hardening Parameters 38
7.3 Workstations Baseline Hardening 41
7.3.1 DCS Workstation BIOS 41
7.3.2 SIS/FGS Workstation BIOS 42
7.4 Thin Client t740 BIOS Hardening Parameters 44
7.5 Schneider Electric Supplied OS Images 45
8 NETWORK TOPOLOGY 46
8.1 Network Segmentation 46
8.2 ICSS Zones Overview 46
8.2.1 Cybersecurity Zone (L3.2) 47
8.2.2 Control System Zone 48
9 NETWORK SWITCH HARDENING 49
9.1 Switch security hardening (VHN/PIN/CS) 49
9.2 Mesh switches security hardening. 50
10 NETWORK FIREWALL HARDENING 51
10.1 FortiGate Firewalls 51
10.2 ConneXium Firewalls 55
11 CENTRALIZED VIRTUALIZATION MANAGEMENT FOR WINDOWS SERVER 2022 56
11.1 Hyper-V Manager 56
11.2 Cybersecurity Virtual Machines 58
11.3 Virtual Host Server Firewalls 60
12 DOMAIN CONTROLLERS 65
12.1 Active Directory Overview 65
12.2 Overview of Domain Controllers Roles 65
12.2.1 Operational Setup 65
12.2.2 Replication Configuration 66
12.2.3 Failover Process 66
12.3 Active Directory Structure 66
12.3.1 Organizational Units (OU) 67

General

12.3.2 Organizational Unit Structure for CCS v9.8 67
12.3.3 Customized Organization Unit 68
12.3.4 Security Groups 68
12.3.5 Security Group Policies and Group Policy Objects 68
12.3.6 Security Users and Security Groups for CCS v9.8 69
12.4 Group Policy Management 71
12.4.1 Group Policies Naming Conventions 73
12.4.2 Group Base-Level and Enhanced-Level Security Group Policies 73
12.4.3 Base-Level Group Policy Descriptions 74
12.4.4 Group Enhanced-Level Group Policy Descriptions 79
12.4.5 CVM Host Server (V95) Group Policies 80
12.5 Customized Group Policies 81
12.5.1 Foxboro Server 2022 Member Server Security Compliance v1.1 81
12.5.2 Foxboro Win10 21H2 Computer Security Compliance v1.1 81
12.5.3 Schneider Electric Windows Event Forwarding WEF Client v1.0 81
12.5.4 S Schneider Electric Windows Update Service (WSUS) Policy v1.0 82
12.5.5 Schneider Electric Bginfo Policy v1.0 83
12.5.6 Schneider Electric NTP Policy for Domain Controllers v1.0 83
12.5.7 Schneider Electric NTP Policy for Non-IA Computers v1.0 83
12.5.8 Schneider Electric SNMP Enablement for NPM v1.0 83
12.6 Linking and Filtering Group Policies 83
12.7 DNS Server Security 86
12.7.1 Secure Dynamic Updates 86
12.7.2 Restricting Zone Transfers 86
12.7.3 DNS Audit and Log Settings 86
12.7.4 DNS Server Permissions 86
12.7.5 Protection against Name Pollution 87
12.8 Time Synchronization 87
12.9 Port Configuration: 87
12.10 Non-Repudiation: 88
13 STANDALONE WINDOWS HARDENING 89

13.1 Group Policy for Computer Settings 89
13.2 Group Policy for Administrator User Accounts 89
13.3 Group Policy for Non-Administrator User Accounts 90
14 NTP SERVER 91
14.1 NTP Server Security and hardening 91
15 MICROSOFT NPS (RADIUS) SERVER 92
15.1 Network Policies 92
15.2 Radius Client Configuration 93
16 CERTIFICATE AUTHORITY 94
16.1 Public Key Infrastructure (PKI) Architecture 94
16.2 Certificate Authority Configuration 94
16.3 Certificate Revocation Strategy 94
16.4 TPM-Based Key Protection 95
16.5 Certificate Template Design 95
16.6 Identity Mapping and Trust 95
16.7 Certificate Authority Settings 96
16.8 Firewall Port Configuration: 96
17 CENTRALIZED PATCH MANAGEMENT 97
17.1 Configurations 97
17.2 WSUS Authentication 98
17.3 Windows Update Criteria 98
17.4 Computers Windows Update Settings 98
17.5 Importing Offline updates without direct Internet connectivity to WSUS 98
18 STANDALONE PATCH MANAGEMENT 99
19 CENTRALIZED ENDPOINT PROTECTION 100
19.1 End Point Security (ENS) 101
19.2 ePolicy Orchestrator 101
19.2.1 ePO Authentication 102
19.2.2 ePO synchronization with the Active Directory servers 102
19.3 Trellix agent 103
19.4 Device Control (DLP) 103

General

19.5 Trellix Application Change and Control (TACC) Solidcore 103
19.6 Trellix Updates 105
19.7 Schneider Electric Supplied Policies 106
19.8 Scan Schedule 106
20 STANDALONE TRELLIX ENDPOINT PROTECTION 107
20.1 Endpoint Security (ENS) 107
20.2 Threat Prevention 107
20.3 Exploit Prevention Content 107
20.4 Trellix Application Change and Control (TACC) Solidcore 107
20.5 Trellix Updates 109
20.6 Schneider Electric Supplied Policies 109
21 CENTRALIZED BACKUP AND RECOVERY 110
21.1 Backup Authentication 110
21.2 VSR Backup Mechanism 110
21.3 Offsite Replication 111
21.4 Backup Schedule 111
21.5 Centralized Backup Server 111
22 STANDALONE BACKUP AND RECOVERY 112
22.1 VSR Backup Mechanism 112
22.2 Backup Schedule 112
23 LOG MANAGEMENT 113
23.1 Log sources. 113
23.2 Events Collecting. 113
23.3 Port Configuration: 113
23.4 Log Forwarding. 113
23.5 Events Timestamp 114
23.6 Logs override 114
24 NETWORK PERFORMANCE MONITORING (NPM) 115
24.1 NPM Monitoring Protocols 115
24.2 NPM monitoring details. 115
24.3 NPM Authentication 116

General

24.4 NPM Alert Center 116
24.4.1 Alert Triggers 116
24.4.2 Monitoring Types 116
24.4.3 Alert Threshold Configuration 117
24.5 NPM Asset Inventory 117
25 APPENDIX-A "EPO – SCAN SCHEDULE" 118
26 APPENDIX-B "VSR – BACKUP SCHEDULE" 119
27 APPENDIX-C SYSTEM UNDER CONSIDERATION 120
28 APPENDIX-D IEC 62443 SL TABLE OF COMPLIANCE 121
29 APPENDIX-E LIST OF DCS THIRD PARTY INTERFACES IN RMP DCS SYSTEM 122
30 APPENDIX-F ROLE BASED ACCESS CONTROL (RBAC) 123
31 APPENDIX-G TRELLIX ENS SCHNEIDER SUPPLIED POLICIES SETTINGS 124
32 APPENDIX-H SCHNEIDER ELECTRIC ACTIVE DIRECTORY GROUP POLICIES 146

General

1 INTRODUCTION

1.1 Introduction and Overview

Foxboro DCS System was installed in KNPC RMP in the year 2000. Numerous upgrades and expansions have opened over the years. The current Foxboro System in RMP is a Windows Based system with Foxboro MESH network and multiple OS/DCS versions (8.x/9.x). RMP DCS System is split into seven areas (WS#1 to WS#7) and is spread across the following locations:

- RMPCCR
- RCC
- SIH:
  - UCR
  - RCR
  - NGOD
  - FAR-107
  - FAR-144
  - FAR-153

The Existing DCS System in RMP has two portions:

- Work group-based system.
  - WS#3, WS#4 and RMP Brownfield units in RMPCCR,
  - UCR,
  - FAR-107
  - FAR-144
  - FAR-153
- Security Enhanced Domain based System
  - WS#1, WS#2, WS#5 and WS#7 in RMPCCR/NGOD/RCR

The existing cybersecurity infrastructure (Supplied as part of CA/CPC/0297) in RMP DCS consists of following components:

1. Cybersecurity servers
   - Primary Domain Controller (RMPPDC)
   - Secondary Domain Controller/Centralized ePO (RMPSDC)
   - Centralized Backup Server (RMPBKP)
   - WSUS Server (RMWSUS)

   Note: The above servers are installed with Windows Server 2016 OS.

2. Redundant ICSS Firewall RMFW01, RMFW02
3. Redundant PIN Root and Backup Root Switches (RMPNRT, RMPNBK)
4. PIN Edge Switches (Non-Redundant) in RMPCCR, NGOD, RCR (RMPN01, RMPN02, RMPN03, RMPN04)

General

As part of this project, existing cybersecurity system will be upgraded as detailed in the subsequent sections. All upgraded DCS servers and workstations (running Windows Server 2022 and Windows10 LTSC) as well existing secured DCS Servers and workstations of WS#1,2,5,7 (running Windows Server 2016 and Windows10 LTSB) will be integrated to the upgraded cybersecurity system.

1.2 Document Purpose

The purpose of this document is to define the cybersecurity system design principles and functionality employed to minimize cybersecurity risks to meet the Company's industrial systems cybersecurity philosophy and specification requirements.

Configuration items and Hardening settings will be detailed and agreed in the detailed design. The parameters and configuration items listed in this FDS is for illustration purposes only and are subject to change as per KNPC requirements.

This document requires approval of KNPC prior to procurement and implementation by Schneider Electric Systems

1.3 Project Information

Customer & End User	Kuwait National Petroleum Company, Mina Al Ahmadi
Project Name	UPGRADING OF EXISTING DCS SYSTEMS & ASSOCIATED EQUIPMENT FOR CYBER SECURITY COMPLIANCE AT RMP CCR & OMCCR IN MAA REFINERY
Contract No	CA/CPC/0707
System Type	Foxboro DCS
Location	Mina Al Ahmadi Refinery, Kuwait

1.4 Objective

- Define the design principles and functionality of the system to be applied to meet the company security profiles requirements defined in the industrial security philosophy.
- Describe the hardware and software configuration of each element.
- Define the make/models and quantities of major hardware component.

General

1.5 Reference Documents

Documents which constitute the basis for this FDS are:

- Functional Design Specification RMP (ME-20420-RMP-FDS-001)
- Schneider Electric Systems Technical Proposal OP-190926-8922920
  - Annexure1: Technical Proposal for RMP Upgrade & Cybersecurity Implementation Scope
  - Annexure7: Table Of Compliance
- Schneider Electric Systems Site Survey Document ME-20420-RMP-SSR-001
- Foxboro DCS Documentation
- Contract Document CA/CPC/0707

1.5.1 International Electrotechnical Commission

- IEC 62443–3–3 Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels.
- IEC 62443–4–1 Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements.
- IEC 62443–4–2 Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components.

1.5.2 HOLD

HOLD	PAGE	DESCRIPTION
HOLD-1	112	Log forwarding

General

1.6 Abbreviations

Anonyms	Abbreviations
AD	Active Directory
AHCI	Advanced Host Controller Interface
AIA	Authority Information Access
ALT	Alternate Key
AMcore	Anti-Malware Core
AMS	Alarm Management System
AMSI	Antimalware Scan Interface
AMT	Active Management Technology
API	Application programming interface
BIOS	Basic Input / Output System
BITS	Background Intelligent Transfer Service
CA	Certificate Authority
CASP	Critical Address Space Protection
CCS	Control Core Services
CD/DVD	Compact Disk/Digital Versatile Disk.
CDMA	Code-Division Multiple Access
CDP	CRL Distribution Point
CD-RW	Compact Disc Re-Writable
CEIP	Customer Experience Improvement Program
CEMS	Common Export Manifold Station
CentOS	Community Enterprise Operating System
Cert	Certificate
CLSIDs	Class identifier
CMD	Command
CNI	Control Network interface
COM	Component Object Model
CPU	Central Processing Unit
CRL	Certificate Revocation Lists
CS	Cybersecurity
CTRL	Control
CVM	Centralized Virtual Machine Management
D96	Schneider Electric Model D96 Workstation for Windows
DAT	Data file
DC	Domain Controller

General

Anonyms	Abbreviations
DCOM	Distributed Component Object Model
DCS	Distributed Control System
DDR	Double data rate
DEL	Delete
DFS	Distributed File System
DHCP	Dynamic Host Configuration Protocol
DLL	Dynamic link library
DLP	Data Loss Prevention
DMZ	Demilitarized Zone
DNS	Domain Name System
DVD	Digital video disc
EKU	enhanced key usage
ENS	Endpoint Security
ePO	ePolicy Orchestrator
EWS	Engineering Workstation
EXE	Execute
FAT	Factory Acceptance Test
FC	FortiCare
FD	Function Discovery
FG	FortiGate
FRS	File Replication Service
GB	Gigabyte
Gbps	Gigabits per second
GCS	Global Customer Support
GE	Giga Ethernet
GPO	Group Policy Object
GSM	Global System for Mobile communication
GTI	Global Threat Intelligence
GUI	Graphical User Interface
H94	Schneider Electric Workstation Server Model H94 For Windows-based on HP DL380 G11 Rackmount server
HA	High Availability
HDD	Hard Disk Drive
HMI	Human-Machine Interface
HP	Hewlett Packard
HPE	Hewlett Packard Enterprise
HTTP	Hypertext Transfer Protocol

General

Anonyms	Abbreviations
HTTPS	Hypertext Transfer Protocol Secure
I/O	Input / output
IA	Industrial Automation
IAS	Internet Authentication Service
ICMP	Internet Control Message Protocol
ICS	Industrial Control System
ICSS	Integrated Control and Safety System
ID	Identification
IDS	Intrusion Detection System
IEEE	Institute of Electrical and Electronics Engineers
IIS	Internet Information Services
iLO	HPE Integrated Lights-Out
INI	initialization
IOT	Internet of Things
IP	Internet Protocol
IPS	Intrusion prevention system
IPsec	Internet Protocol security
iSCSI	Internet Small Computer System Interface
KB	kilobyte
LAN	Local Area Network
LDAP	Lightweight Directory Access Protocol
LFF	Large Form Factor
LGPO	Local Group Policies
LLDP	Link layer discovery protocol
LOM	LAN-on-motherboard
LP	Language packs
LSA	Local Security Authority
MAC	Media Access Control
MB	Megabytes
Mbps	Megabits per second
ME	Management Engine
MGMT	Management
MIME	Multipurpose Internet Mail Extensions
MP	Malware Protection
Mpps	Million Packets per Second
MS	Microsoft
MSI	Microsoft Installer

General

Anonyms	Abbreviations
MSSQL	Microsoft Structured Query Language
NA	Not applicable
NAP	Network Access Protection
NetBIOS	Network Basic Input/Output System
NetBT	NetBIOS
NGFW	Next Generation Firewall
NIC	Network Interface Card
NIST	National Institute of standards and technology
NPM	Network Performance Monitor
NPS	Network Policy Server
NTFS	New Technology File System
NTP	Network Time Protocol
NX	No Execute
OOB	Out of Band Management Network
OPC	OLE for Process Control
OS	Operating System
OU	Organizational Unit
OWS	Operator Workstation
PC	Personal computer
PCD	Process Control & Systems department
PCIe	peripheral component interconnect expresses
PCS	Process Control System
PDC	Primary Domain Controller
PIN	Plant Information Network
PLC	Programmable Logic Controller
PnP	Plug and Play
PNRP	Peer Name Resolution Protocol
PXE	Pre-boot execution environment
RAID	Redundant Array of Independent Disks
RAM	Random-access Memory.
RAS	Remote Access Service
RBAC	Role Based Access Control
RD	Remote Desktop
RDCS	Remote Desktop Configuration service
RDP	Remote Desktop Protocol
ROM	Read-only memory
RPC	Remote Procedure Call

General

Anonyms	Abbreviations
RPCSS	Remote Procedure Call Server Service
RSA	Rivest, Shamir, Adleman
RSH	Remote shell
SAN	Subject Alternative Name
SAS	Serial-Attached SCSI solid-state drive
SATA	Serial Advanced Technology Attachment
SC	Smart Carrier
SCSI	Small Computer System Interface
SD	Secure Digital
SDC	Secondary Domain Controller
SE	Schneider Electric
SFP	Small Form-Factor Pluggable
SFTP	Secure File Transfer Protocol
SHA	Secure Hash Algorithm
SIS	Safety Instrumented Systems
SMB	Server Message Block protocol
SNMP	Simple Network Management Protocol
SQL	Structured Query Language
SQM	Software Quality Metrics
SRV	Server
SSDP	Simple Services Discovery Protocol
SSH	Secure Shell
SSL	Secure Sockets Layer
SSTP	Secure Socket Tunneling Protocol
SVCHOST	Service Host
TA	Trellix Agent
TACC	Trellix Application and Change Control
TAPI	Telephony API
TBA	To be advised
TBD	To be decided
TCP	Transmission control protocol
TCP/IP	Transmission Control Protocol/Internet Protocol
TFTP	Trivial File Transfer Protocol
TIE	Threat Intelligence Exchange
TLS	Transport Layer Security
TPM	Trusted Platform Module
TS	Tristation

General

Anonyms	Abbreviations
UAS	USB Attached SCSI
UEFI	Unified Extensible Firmware Interface
UI	User Interface
UNC	Universal Naming Convention
URL	Uniform Resource Locator
USB	Universal System Bus
V95	Schneider Electric Virtual host Server Model V95
VHN	Hyper-V Network
VLAN	Virtual Local Area Network
VM	Virtual Machine
VPN	Virtual Private Network
VSR	Veritas System Recovery
VT	Virtualization Technology
WAN	Wide Area Network
WEF	Windows Event Forwarder
WIN	Windows
WinRM	Windows Remote Management
WinRT	Windows Runtime
WINS	Windows Internet Name Service
WISVC	Windows Insider Service
WS	Workstation
WSUS	Windows Server Update Services
XML	extensible markup language

General

2 SCOPE OVERVIEW

This section provides an overview of the scope of work covered in this document.

- Replacement /Upgrade of Existing Cybersecurity system in RMP:

New cybersecurity system supplied will have following servers at L3.2:

- Virtual Server (RMCSV1) with following functions setup in Virtual environment
  - Primary Domain Controller (PDC) for DCS servers and workstations + Radius Server.
  - Log Management Server.
  - ePO (Centralized Endpoint Protection System).

  Note: Above functions except domain controller/Radius Server will be replicated in the virtual Server2

- Virtual Server (RMCSV2) with following functions setup in Virtual environment
  - Secondary Domain Controller (SDC) for DCS Servers and workstations + Radius Server
  - Network performance Monitoring.
  - Windows Server Update Services (WSUS) Server.
  - Certificate Authority Server (CA) Server.

  Note: Above functions except domain controller/Radius Server will be replicated in the virtual Server1

- Centralized Backup server (RMPBK1)

Note:

1. RMCSV1 and RMPBK1 shall be installed in place of existing servers (RMPPDC and RMPBKP) in the cabinet RMP-DCS-SVR-001.
2. RMCSV2 shall be installed in place of existing server (RMPSDC) in the cabinet RMP-DCS-SVR-002

- Replacement/upgrade of existing ICSS firewall RMFW01, RMFW02 in RMPCCR. Existing ICSS firewall (CFPFW1) in brownfield portion (in RMPCCR) shall be demolished. All brownfield stations post upgrade will be integrated to new PIN network which will be connected to upgraded ICSS firewall RMFW01/02.

- Supply and configuration of L1 Firewall for all existing 3rd party TCP/IP non-Schneider Electric interfaces with DCS System. L1 Firewall shall be installed in the existing DCS System Cabinets in the spare space reserved.

- Replacement / upgrade of existing obsolete primary PIN switches in RMP DCS network.

General

- Supply and configuration of new secondary PIN network Switches in RMP DCS network.
- Standalone Host hardening for the Triconex Workstations in RMP

- Supply and configure Veritas System recovery Software for standalone Triconex workstations for RMP.

- Supply and configure Trellix ENS Software for standalone TRICONEX workstations for RMP.

- Network hardening for the newly supplied PIN switches and firewalls.

- Configuration of SPAN Port for L2 MESH & L3 PIN Root Switches:

    - In RMPCCR, Port Mirroring shall be configured for the upgraded DCS L2 MESH Root Switches (Primary/Secondary) to route the network traffic to a physical SPAN port. The SPAN Port shall be connected to existing aggregator switch in the same location.

    - In RMPCCR, Port Mirroring shall be configured for the upgraded DCS L3 PIN Root Switches (Primary/Secondary) to route the network traffic to a physical SPAN port. The SPAN port shall be connected to existing aggregator switch in the same location.

      Note: If SPAN Configuration required additionally on individual L2/L3 edge switches also to existing aggregator installed in respective locations, the same can be configured depending on the spare ports' availability. Any MGBICs required on SE switches and cables to connect with Nozomi Aggregator switches within in the same building will be provided by Schneider. Any MGBICs required on the Nozomi Aggregator or guardian for interconnection with SE Switches SPAN port will be provided by KNPC IT team.

- Syslog Server will be configured to receive logs from all the DCS workstations, Servers, and PIN switches. All logs will be forwarded to the KNPC IT Security Information and Event Management (SIEM) using a KNPC-provided log collector/forwarder at L3.5. Any configuration for integration with existing QRadar SIEM shall be under KNPC scope.

General

3 SYSTEMS UNDER CONSIDERATION

Refer to Appendix C for details.

General

4 HARDWARE OVERVIEW

This section contains the details of the proposed hardware to be supplied as part of this project.

4.1 Cybersecurity Servers:

RMP CCR:

- New V95 Virtual servers (RMCSV1, RMCSV2) shall be provided in RMPCCR. New servers will be installed in existing cabinets RMP-DCS-SVR-001 & RMP-DCS-SVR-002. Existing Rack displays in the cabinet shall be utilized.
- One thin client with new 24" LCD Monitor shall be provided to access the virtual machines from the RMPCSV1 and RMPCSV2 Servers.

Name	Model No	Manufacturer	Supplier	Function
RMCSV1	V95	HPE	SE	Cyber security server
RMCSV2	V95	HPE	SE	Cybersecurity Server
RMPBK1	HPE	HPE	SE	Centralized Backup Server (48TB)

General

4.2 L3 DCS PIN/CS Switches

As part of this project, existing obsolete L3 PIN switches shall be upgraded with new L3 PIN switches in an optimized manner and new redundant PIN switches shall be provided. Details of existing and proposed model and new switches are mentioned below:

WS#	Location	Existing PIN Switch Letter bug	Existing Type	Proposed PIN Switch Letter bug	Proposed Model	Description
Common	RMPCCR	RMPNRT	X-Series	RMPNRT	RH102BG	48 Port SFP Switch
Common	RMPCCR	RMPNBK	X-Series	RMPNBK	RH102BG	48 Port SFP Switch
RMP Brownfield	RMPCCR	RMPPNR	C-Series	-	-	Shall be decommissioned. (Old Root for RMP Brown Field Portion)
WS#1	RCC	WS1PCN	I-Series	RMPN01	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#1	RCC	-	-	RMPN02	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#2	RCC	WS2PCN	I-Series	RMPN03	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#2	RCC	-	-	RMPN04	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#3	RCC	WS3PCN	I-Series	RMPN05	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#3	RCC	-	-	RMPN06	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)

General

WS#	Location	Existing PIN Switch Letter bug	Existing Type	Proposed PIN Switch Letter bug	Proposed Model	Description
WS#4	RCC	WS4PCN	I-Series	RMPN07	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#4	RCC	-	-	RMPN08	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#5	RCC	WS5PCN	I-Series	RMPN09	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#5	RCC	-	-	RMPN10	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#6	RCC	WS6PCN	I-Series	RMPN11	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#6	RCC	-	-	RMPN12	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#7	RCC	WS7PCN	I-Series	RMPN13	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
WS#7	RCC	-	-	RMPN14	RH102BM	24 Port Copper Switch (Common for WS#1 to 7)
Common	RCC	-	-	RMPN15	-	Existing 24 Port PIN Root Switch from RMPCCR shall be used

General

WS#	Location	Existing PIN Switch Letter bug	Existing Type	Proposed PIN Switch Letter bug	Proposed Model	Description
Common	RCC	-	-	RMPN16	;-	Existing 24 Port PIN Backup Root Switch from RMPCCR shall be used
WS#7	RCR	RMPN04	X-Series	RMPN17	-	Existing Switch already upgrade to X-Series
WS#7	RCR	-	-	RMPN18	RH102BM	24 Port Copper Switch
WS#7	107-FAR	107PN1	I-Series	RMPN19	RH102BM	24 Port Copper Switch
WS#7	107-FAR	-	-	RMPN20	RH102BM	24 Port Copper Switch
WS#1	144-FAR	144PN1	I-Series	RMPN21	RH102BM	24 Port Copper Switch
WS#1	144-FAR	-	-	RMPN22	RH102BM	24 Port Copper Switch
WS#4	153-FAR	153PN1	I-Series	RMPN23	RH102BM	24 Port Copper Switch
WS#4	153-FAR	-	-	RMPN24	RH102BM	24 Port Copper Switch
WS#1	NGOD SIH	RMPN03	X-Series	RMPN25	-	Existing Switch already upgrade to X-Series
WS#1	NGOD SIH	-	-	RMPN26	RH102BM	24 Port Copper Switch
WS#4	UCR	-	-	RMPN27	RH102BM	24 Port Copper Switch
WS#4	UCR	-	-	RMPN28	RH102BM	24 Port Copper Switch
WS#1/2	RMPCCR	RMPN01	X-Series	RMPN29	-	Existing Switch already upgrade to X-Series
WS#1/2	RMPCCR	-	-	RMPN30	RH102BM	24 Port Copper Switch
WS#5/6/7	RMPCCR	RMPN02	X-Series	RMPN31	-	Existing Switch already upgrade to X-Series

General

WS#	Location	Existing PIN Switch Letter bug	Existing Type	Proposed PIN Switch Letter bug	Proposed Model	Description
WS#5/6/7	RMPCCR	-	-	RMPN32	RH102BM	24 Port Copper Switch
WS#3	RMPCCR	-	-	RMPN33	RH102BM	24 Port Copper Switch
WS#3	RMPCCR	-	-	RMPN34	RH102BM	24 Port Copper Switch
WS#4	RMPCCR	-	-	RMPN35	RH102BM	24 Port Copper Switch
WS#4	RMPCCR	-	-	RMPN36	RH102BM	24 Port Copper Switch
RMP Brownfield	RMPCCR	RMPPN1	I-Series	RMPN37	RH102BM	24 Port Copper Switch
RMP Brownfield	RMPCCR	-	I-Series	RMPN38	RH102BM	24 Port Copper Switch
RMP Brownfield	RMPCCR	-	-	RMPN39	RH102BM	24 Port Copper Switch
RMP Brownfield	RMPCCR	-	-	RMPN40	RH102BM	24 Port Copper Switch
Common	RMPCCR	-	-	RMCS01	RH102BM	24 Port Copper Switch
Common	RMPCCR	-	-	RMCS02	RH102BM	24 Port Copper Switch

General

4.3 L3 Firewall

As part of this project, existing ICSS firewall (Fortinet Firewall FG101E) will be replaced by latest ICSS firewall (Fortinet FG401F). Details below:

WS#	Location	Existing Firewall Letterbug	Existing Type	Proposed Firewall Letterbug	Proposed Model	Description
Common	RMPCCR	RMFW01	FG-101E	RMFW01	FG-401F	ICSS Firewall
Common	RMPCCR	RMFW02	FG-101E	RMFW02	FG-401F	ICSS Firewall

4.4 L1 Firewall

As part of this project, L1 firewall will be provided for interfacing 3rd party TCP/IP non-Schneider Electric interfaces with DCS System (FDSI FBM233). Details below:

Location	WS	Proposed Firewall Name	Proposed Firewall Model	FDSI FBM Letter bug	Protocol
RMP	WS#4	057FW5/06	ConneXium	57850A	OPC DA
RMP	WS#1	043FW1/02	ConneXium	43210A	MODBUS
RMP	WS#2	041FW1/02	ConneXium	41110B	MODBUS
RMP	WS#3	048FW1/02	ConneXium	48510B	MODBUS
RMP	WS#4	051FW1/02	ConneXium	51610B	MODBUS
RMP	WS#4	051FW3/04	ConneXium	51620B	MODBUS
RMP	WS#4	057FW1/02	ConneXium	57610A	ETHERNETIP
RMP	WS#4	051FW5/06	ConneXium	51710A	MODBUS
RMP	WS#4	057FW3/04	ConneXium	57760A	MODBUS
RMP	WS#5	080FW1/02	ConneXium	80120C	MODBUS
UCR	WS#4	097FW1/02	ConneXium	97320A	MODBUS
UCR	WS#4	097FW3/04	ConneXium	97320B	MODBUS
UCR	WS#4	097FW5/06	ConneXium	97320C	MODBUS
UCR	WS#4	105FW1/02	ConneXium	10530A	MODBUS
107-FAR	WS#7	107FW1/02	ConneXium	I1140B	MODBUS
107-FAR	WS#7	107FW3/04	ConneXium	I1240B	MODBUS
107-FAR	WS#7	107FW5/06	ConneXium	I1340A	MODBUS
107-FAR	WS#7	107FW7/08	ConneXium	I1340C	MODBUS
107-FAR	WS#7	125FW1/02	ConneXium	I2140C	MODBUS
107-FAR	WS#7	125FW3/04	ConneXium	I2141B	MODBUS
144 FAR	WS#1	144FW1/02	ConneXium	G1140B	MODBUS
144 FAR	WS#1	144FW3/04	ConneXium	G1240B	MODBUS

General

Location	WS	Proposed Firewall Name	Proposed Firewall Model	FDSI FBM Letter bug	Protocol
144 FAR	WS#1	144FW5/06	ConneXium	G1340C	MODBUS
153 FAR	WS#4	153FW1/02	ConneXium	H1240C	MODBUS
RCR	WS#7	025FW1/02	ConneXium	25230A	MODBUS
RCR	WS#7	025FW3/04	ConneXium	25230B	MODBUS
107-FAR	WS#7	329FW1/02	ConneXium	I3140B	OPC DA
107-FAR	WS#7	329FW3/04	ConneXium	I3140C	OPC DA
107-FAR	WS#7	329FW5/06	ConneXium	I3240B	MODBUS
107-FAR	WS#7	329FW7/08	ConneXium	I3241A	MODBUS
RMP	WS#2	042FW1/02	ConneXium	42120B	MODBUS
UCR	WS#4	057FW7/08	ConneXium	57310A	MODBUS
NGOD	WS#1	058FW1/02	ConneXium	58910A	MODBUS
RCC	COMMON	GHIFW1/02	ConneXium	C1120D	OPC DA
RMP-server extension room	COMMON	GHIFW3/04	ConneXium	C1240A	OPC DA
RMP-server extension room	COMMON	GHIFW5/06	ConneXium	C1240B	OPC DA

General

5 SOFTWARE OVERVIEW

This section is to provide details about list of software and licenses supplied as part of Schneider Electric Cybersecurity project scope.

5.1 List of Software

#	Name	Version	Function	Installed On
1	Microsoft SQL	SQL Server 2022 Standard	Trellix database	RMPEPO
2	Microsoft SQL	SQL Server 2022 Standard	NPM database	RMPNPM
3	WhatsUp Gold NPM	v24.0	Network performance monitoring	RMPNPM
4	WhatsUp Gold Log Management	v24.0	Log Management	RMPNPM
5	WhatsUp Gold Virtual Monitoring	v24.0	Virtual Infrastructure Monitoring	RMPNPM
6	WhatsUp Gold Configuration Management	v24.0	Automated management & auditing network devices	RMPNPM
7	Kiwi Syslog forwarder	NG v1.2	Log Management	RMPLOG
8	Trellix EPP (ePO Managed)	ePO 5.10 SP1 Trellix Agent – 5.7 Trellix ENS – 10.7 Trellix TACC – 8.3 Trellix DLP – 11.10 Trellix RSD – 5.0.6	Endpoint Protection	RMPEPO (For DCS Servers/ Workstations)
9	Trellix EPP (Self-Managed)	Trellix ENS 10.7 Trellix Agent 5.7.x	Endpoint Protection	For Triconex SIS/ FGS workstations
10	Veritas System Recovery Server edition	v23	Backup management	All Servers
11	Veritas System Recovery Virtual edition	v23	Backup management	DCS/Cyber Virtual Machines
12	Veritas System Recovery Desktop edition	v23	Backup management	DCS & Triconex SIS/ FGS workstations

General

5.2 List of Licenses

#	Name	Part Number	Function
1	FG-401F License	FC-10-0401F-811-02-36	Enterprise Protection (IPS, Advanced Malware Protection, Application Control, , Industrial Security, , and FortiCare Premium)
2	FG-401F License	FC-10-0401E-159-02-36	FortiGuard OT Security Service (OT dashboards and compliance reports, OT application and service detection, signatures - Application Control and IPS rules)
3	Kiwi syslog server	KSS NG 1.2	Centralized log management from windows endpoints and network devices
4	Trellix EPP	-	License for Trellix security products on endpoints: ePO Trellix Agent Endpoint Security Rogue System Detection Application and Change Control Device Control (DLP)
5	Veritas System Recovery 23	-	Veritas system recovery desktop edition 23
		-	Veritas system recovery server edition 23
		-	Veritas system recovery virtual edition 23
6	WhatsUp Gold (WUG)	-	WhatsUp Gold Premium 500 New Devices
		-	WhatsUp Gold Virtual Monitoring 500 New Devices
		-	WhatsUp Gold Configuration Management plug-in 500 New Devices

General

6 CYBERSECURITY HARDWARE SPECIFICATIONS

6.1 Server Hardware Specification

6.1.1 V95 Server Specification

Note: This image represents a fully configured server and might show configuration options (for example, hard disks or PCI cards) that are not part of this project servers specs.

Specification

- Microsoft Hyper-V virtualization technology through the pre-configured and installed Windows Server 2022 physical operating system environment (POSE)
- 2 X HPE DL380 Gen11 Intel Xeon-Silver 4510 (2.4 GHz/12-core/150W) Processor
- Quad head graphics card with four mini-DP ports, four adapters from mini-DP to standard display port are provided.
- 256 GB DDR-5 Registered Memory
- Hard drives (HDDs)
    - 2 X 600 GB SAS RAID 1 for operating system
    - 4 X1.2 TB SAS hard drives.
- Four integrated 10/100/1000Base-TX Ethernet ports
- Internal SATA CD-RW/DVD drive
- Redundant hot-swap power supplies
- Redundant hot-swap fans.

General

6.1.2 HPE Backup Server Specification

HPE Backup Server running the Microsoft Windows Server operating system, it supports the offline Tier-2 Backup function.

Specification

- Intel Xeon Processor
- Pre-configured and installed Microsoft Windows Server 2022 IOT operating system.
- 1 x 16 GB DDR-4 Memory
- HPE 8 X 6TB SAS LFF SC
- HPE Smart array storage controller.
- Internal SATA CD-RW/DVD drive
- Integrated 10/100/1000BaseT Ethernet ports
- Redundant hot-swappable power supplies
- Mounting rail kit

General

6.2 L3 Network Switches Hardware Specification

6.2.1 RH102BG 48-Gigabit SFP Managed Switch

RH102BG managed switch provides 48 SFP 1000Base-X 1 Gb uplink ports.

48-gigabit (SFP) 5520 managed switch (RH102BG)

Specification

The 48-Gigabit (SFP) 5520-Series managed switch (RH102BG) has these features:

- 48 x 100/1000Base-X (SFP) unpopulated ports. (The SFP ports can be configured as 100 /1000 Base-FX /Tx with the appropriate GBIC transceiver.) Full-duplex operation.

6.2.2 RH102BM 24-Gigabit 10/100/1000 Base-Tx Managed Switch

The 24-Port Tri-Speed 10/100/1000Base-Tx port managed switch (RH102BM) has these features:

- 24 x 10/100/1000Base-Tx “Fixed” (RJ-45) ports.

General

6.3 Firewall Hardware Specification

6.3.1 FortiGate-401F

FortiGate-401F Firewall will be utilized as the L3.2 Firewall to control traffic flow, inspect the traffic, and enforce zones boundaries.

Specifications:

#	Feature	Specs
1	Firewall Model Code	FG-401F
2	FortiOS Firmware version	7.6
3	Firewall Throughput (Mpps)	105
4	IPS Throughput	12 Gbps
5	NGFW Throughput	10 Gbps
6	Threat Protection Throughput	9 Gbps
8	Maximum concurrent sessions (TCP)	7.8 million
9	New Sessions/Second (TCP)	500,000
10	High Availability Configurations	Active / Active, Active / Passive, Clustering
11	Firewall Policies (max)	10,000
12	Number of GE RJ45 Interfaces	16 + 2 Management, + 1 HA
13	Number of GE 10G SFP+ Interfaces	8
14	Number of GE SFP Interfaces	8
15	SSD Hard disk	2x480GB onboard storage

General

6.3.2 Third-Party Interface Firewalls.

6.3.2.1 ConneXium

#	Feature	Specs
1	Firewall Model Code	TCSEFEA23F3F22
2	Concept	Transparent Ready
3	Communication port protocol	Ethernet TCP/IP SSH HTTP HTTPS SNMP SFTP SCP LLDP
4	Deep Packet Inspection	Modbus/OPC/EIP Enforcer
5	Port Ethernet	10BASE-T/100BASE-TX - 2 port(s) copper cable
6	Cybersecurity	Role-based access control Syslog protocol support IPSec DoS prevention Built-in firewall MAC addresses filtering

General

7 WINDOWS MACHINES HARDENING BASELINE

The following section illustrates Schneider Electric hardening for all Schneider Electric supplied servers, workstations and thin clients by incorporating security design principles such as Secure-by-default, Least Functionality, and defense in depth.

The hardening will be carried out in this order:

- BIOS Hardening
- OS Hardening

7.1 V95 Server BIOS Hardening Parameters

The following table provides the BIOS parameters values that will be used for all V95 Servers BIOS Security:

Parameter Name	Value
System Configuration > BIOS/Platform Configuration (RBSU) > Workload Profile	[Virtualization-Max Performance]
System Configuration > BIOS/Platform Configuration (RBSU) > Boot Options > UEFI Boot Settings > UEFI Boot Order	Windows Boot Manager
System Configuration > BIOS/Platform Configuration (RBSU) > Advanced Options > Video Options	[Add-in Video Enabled, Embedded Video Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Access Control Service	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > iSCSI Software Initiator	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > NVMe-oF Software Initiator	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > PCIe Slot Network Boot > OCP Slot 15 Port 1: Broadcom netXtreme Gigabit Ethernet -NIC	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Embedded iPXE > Embedded iPXE	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Power and Performance Options > Disable Dynamic Loadline Switch	[Disabled DLL Switch]

General

Parameter Name	Value
System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Secure Boot Settings > Attempt Secure Boot	[Enabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > Gateway from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > DHCP Routes	[Disabled]
System Configuration > iLO 6 Configuration Utility > > Advanced Network Options > DNS from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > > Advanced Network Options > WINS from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > Register with WINS Server	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > System Options >USB Options > USB Boot Support	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > System Options > Server Availability > Automatic Power On	[Restore Last Power State]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Intel® Virtualization Technology	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Intel VT-d	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Access Control Service	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options >SR-IOV	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Network Options> Pre-Boot Network Settings > DHCPv4	Disabled
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Set Admin Password	Password set
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options > Current TPM State	[Present and Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options > Current TPM 2.0 Active PCRs	[SHA256 and SHA384]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted	FIFO Interface

General

Parameter Name	Value
Platform Module Options > Current TPM 2.0 Software Interface Status	
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM Visibility	Visible
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM UEFI Option ROM Measurement	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM 2.0 Endorsement Hierarchy	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options>TPM 2.0 Storage Hierarchy	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> Omit Boot Device Event	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > Platform Certificate Support	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > Allow login with iLO accounts	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > One Time Boot Menu (F11 Prompt)	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options >Intelligent Provisioning (F10 Prompt)	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options >	[Disabled]

General

7.2 H94 Server BIOS Hardening Parameters

Parameter Name	Value
System Configuration > BIOS/Platform Configuration (RBSU) > Workload Profile	Power Efficient Computer
System Configuration > BIOS/Platform Configuration (RBSU) > Boot Options > UEFI Boot Settings > UEFI Boot Order	Windows Boot Manager
System Configuration > BIOS/Platform Configuration (RBSU) > Advanced Options > Video Options	[Add-in Video Enabled, Embedded Video Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Access Control Service	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > iSCSI Software Initiator	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > NVMe-oF Software Initiator	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Network Boot Options > PCIe Slot Network Boot > OCP Slot 15 Port 1: Broadcom netXtreme Gigabit Ethernet -NIC	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Network Options > Embedded iPXE > Embedded iPXE	[Disabled]
System Configuration > BIOS/Platform Configuration (RBSU) > Power and Performance Options > Disable Dynamic Loadline Switch	[Disabled DLL Switch]
System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Secure Boot Settings > Attempt Secure Boot	[Enabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > Gateway from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > DHCP Routes	[Disabled]
System Configuration > iLO 6 Configuration Utility > > Advanced Network Options > DNS from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > > Advanced Network Options > WINS from DHCP	[Disabled]
System Configuration > iLO 6 Configuration Utility > Advanced Network Options > Register with WINS Server	[Disabled]

General

Parameter Name	Value
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > System Options >USB Options > USB Boot Support	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > System Options > Server Availability > Automatic Power On	[Restore Last Power State]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Intel® Virtualization Technology	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Intel VT-d	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options > Access Control Service	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Virtualization Options >SR-IOV	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Network Options> Pre-Boot Network Settings > DHCPv4	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Set Admin Password	Password set
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options > Current TPM State	[Present and Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options > Current TPM 2.0 Active PCRs	[SHA256 and SHA384]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options > Current TPM 2.0 Software Interface Status	FIFO Interface
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM Visibility	Visible
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM UEFI Option ROM Measurement	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> TPM 2.0 Endorsement Hierarchy	[Enabled]

Parameter Name	Value
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options>TPM 2.0 Storage Hierarchy	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Trusted Platform Module Options >Advanced Trusted Platform Module Options> Omit Boot Device Event	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > Platform Certificate Support	[Enabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > Allow login with iLO accounts	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options > One Time Boot Menu (F11 Prompt)	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options >Intelligent Provisioning (F10 Prompt)	[Disabled]
Menu-System Configuration > BIOS/Platform Configuration (RBSU) > Server Security > Advanced Security Options >	[Disabled]

General

7.3 Workstations Baseline Hardening

7.3.1 DCS Workstation BIOS

The following table provides the BIOS parameters values that will be used for all D96 Workstation BIOS Security:

Parameter Name	Value
BIOS > Boot Configuration > Boot Mode >	UEFI only
BIOS >Boot Configuration > Boot Sequence	Windows Boot Manager
BIOS >Boot Configuration > Enable Secure Boot	Enable
BIOS >Boot Configuration > Enable Microsoft UEFI CA	Enable
BIOS >Boot Configuration > Secure Boot Mode	Deployed Mode
BIOS > Integrated Devices > Enable USB Boot Support	Disable
BIOS > Power > Enable USB Wake Support	Off
BIOS > Power > AC Recovery	Last Power State
BIOS > Security > TPM 2.0 Security On	Enable
BIOS > Security > Attestation Enable	Enable
BIOS > Security > Key Storage Enable	Enable
BIOS > Passwords> Admin Password	Set
BIOS > Passwords> Upper Case Letter	Enable
BIOS > Passwords> Lower Case Letter	Enable
BIOS > Passwords> Digit	Enable
BIOS > Passwords> Special Character	Enable
BIOS > Passwords> Minimal Characters	12
BIOS > Passwords> Password Bypass	Disable
BIOS > Passwords> Allow Non-Admin Password Changes	Disable
BIOS > Passwords> Enable Admin Setup Lockout	Enable
BIOS > Update Recovery > Enable UEFI Capsule Firmware Updates	Disable
BIOS > Update Recovery > BIOS Recovery from Hard Drive	Disable
BIOS > Update Recovery > Allow BIOS Downgrade	Disable
BIOS > Update Recovery > SupportAssist OS Recovery	Disable
BIOS > Pre-boot Behavior > Warnings and Errors	Prompt on Warnings and Errors
BIOS > Pre-boot Behavior > Extend BIOS POST Time	5 Seconds
BIOS > Virtualization Support> Enable Intel® Virtualization Technology (VT)	Disable
BIOS > Pre-boot Behavior > Enable Intel® VT for Direct I/O	Disable

General

7.3.2 SIS/FGS Workstation BIOS

The following table provides the BIOS parameters values that will be used for all HPE Workstation BIOS Security:

Parameter Name	Value
Security > System Security	
Virtualization Technology (VT-x)	Disable
Virtualization Technology for Directed I/O) (VT)	Disable
Trusted Execution Technology (TXT)	Disable (Grayed out, unavailable)
Security > System Management Command	Disable
Create BIOS Administrator Password.	Created
Advanced > Boot Options	
Network (PXE) Boot	Disable
Fast Boot	Disable
Post Delay (in seconds)	5
UEFI Boot Options	Enable
Factory Recovery Boot Support	Disable
Optical Media Boot Support	Disabled
USB Media Boot Support	Disabled
After Power Loss	Previous State
UEFI Boot Order	Windows Boot Manager CD/DVD Drives (Disabled) SATA0 (Disabled) USB Drives (Disabled)
Advanced > System Options	
Power Button Override	4 Seconds
Advanced > Built-In Device Options	
Embedded LAN Controller (AMT)	Disable
S5 Wake On LAN	Disable
Advanced > Port Options	
SATA0	Enable
SATA1	Enable
SATA2	Enable
SATA3	Enable
SATA4	Enable
SATA5	Enable
Advanced > Secure Boot Configuration	
Configure Legacy Support and Secure Boot	Legacy Support Enable and Secure Boot Enabled
Enable MS UEFI CA Key	Disable
Security > System Security	
Advanced > Power Management Options	

Parameter Name	Value
Runtime Power Management	Enable
Hardware P-States	Enable
Energy/Performance Bias	OS Control EPB
Idle Power Savings	Extended
Unique BlinkState	Disable
S5 Maximum Power Savings	Disable
Advanced > Performance Options	
Intel® Hyperthreading Technology	Enable
Active CPU Core Per Processor	All
Turbo Mode	Enable
Isoc Mode	Enable
Workload Configuration	I/O Focused
Advanced > Slot Settings	
Slot 1 Option ROM Download	Enable
Slot 2 Option ROM Download	Disable
Slot 3 Option ROM Download	Disable
Slot 4 Option ROM Download	Disable
Slot 5 Option ROM Download	Disable
Advanced > Remote Management Options	
Intel Management Engine (ME)	Enable
Intel Active Management Technology (AMT)	Disable

General

7.4 Thin Client t740 BIOS Hardening Parameters

The following table provides the BIOS parameters values that will be used for all t740 Thin Client BIOS Security:

Parameters		Value
Storage > Boot order Boot Order		UEFI Boot Sources
		Windows Boot Manager
		USB Hard Drive Disabled
		USB Floppy/CD Disabled
		All UEFI network options Disabled
		Legacy Boot Sources: Disabled
Security > Network Boot	Network Boot	Disable
Security > System Security	Admin Password	Set
	Virtualization Technology	Disable
	TPM Device	Available
	TPM State	Disable
	Clear TPM	Do not reset
Power >OS Power Management	Runtime Power Management	Enable
	Idle Power Savings	Extended
Power >Hardware Power Management	S5 Maximum Power Savings	Disable
Advanced > Power-On Options	POST Messages	Enable
	Press the ESC key for Startup Menu	Displayed
	After Power Loss	Previous State
	Post Delay (in seconds)	5
	Bypass F1 Prompt on Configuration Changes	Disable
	Remote Wakeup Boot Source	Local Hard Drive
Advanced > Bus Options	PCI SERR# Generation	Enable
	PCI VGA Palette Snooping	Disable
Advanced >Option ROM Launch Policy	PXE Option ROMs	UEFI
	PCIE Slot Option ROM Download	Enable

General

7.5 Schneider Electric Supplied OS Images

The OS images supplied by Schneider Electric for the supported platforms have been configured to incorporate security measures such as removing unnecessary software components and turning off services that are not required for Schneider Electric software operation.

The following is a list of changes applied to the Windows OS image to enhance security:

- Removed unused Windows OS components: [All Games], Media Player, Messenger, MSN Explorer, Outlook Express.
- Removed “Favorites” from Start menu.
- Removed “My Pictures” from Start menu.
- Removed “My Music” from the Start menu.
- Removed “Set Program Access and Defaults” from Start menu.
- Disabled unnecessary user accounts (Guest, HelpAssistant, Support_38*).
- Disabled anonymous access and hash password storage.
- Disabled the Shared Documents folder.
- Power button behavior set to: “When I press the power button, do nothing.”
- Disabled unused services.

NOTE: External drives (CD/DVD drive, USB drives) access will be controlled through Trellix Data Loss Prevention when available.

General

8 NETWORK TOPOLOGY

8.1 Network Segmentation

Network segmentation divides the ICSS networks into multiple zones and sub-zones. Each zone has a different set of traffic patterns, security, and connectivity requirements. Segmentation is achieved by placing firewalls at zone boundaries. Intrusion prevention functions are embedded in the internal segmentation NGFW devices.

Firewall filtering strategies:

- The base configuration of the Firewall device will be set to deny all communication by default and only allow communication by exception to meet a critical application need. This applies to both intermittent and interactive user communication, and task-to-task communication between devices in these two zones.
- Ports and servers frequently used as attack vectors will not be opened through the firewall device.
- The fewer the number of ports and services open through the firewall device the better, for OPC traffic, FortiGate firewall is an OPC aware device.

8.2 ICSS Zones Overview

The following section details the security zones implemented within the RMP for Schneider Electric systems at KNPC. These zones are the distinct trust boundaries for Schneider Electric supplied systems. Each zone logically groups assets that share similar security requirements and perform comparable functions. Defining these zones is fundamental to establishing a defense-in-depth strategy, minimizing the impact of potential security breaches by limiting lateral movement, and containing incidents within specific zones.

This Table provides an overview of the security level for each Zone. Refer to Appendix D for IEC62443 Security level Table of Compliance and ME-20420-RMP-ZCD-001 for Overall Zones & Conduit Drawing.

Zone	Functionality	SL
Cybersecurity Zone	Cybersecurity Solutions	3
Control system Zone	Foxboro DCS Control System	1

General

8.2.1 Cybersecurity Zone (L3.2)

The function of this zone is to segregate the cybersecurity network from different zones.

Devices located in the Cybersecurity zone provide central cybersecurity and monitoring functions to Control System Zone and The Cybersecurity zone is segmented using a dedicated Cybersecurity network switch and bounded by ICSS NFGW that can control what passes through the device.

The Cybersecurity Zone contains:

- Cybersecurity virtualized host server - #1
  - Primary domain controller + RADIUS VM
  - Log server VM.
  - ePO VM
  - Replica VMs (WSUS, CA Server, NPM)
- Cybersecurity virtualized host server - #2
  - Secondary domain controller + RADIUSVM
  - WSUS VM
  - CA Server VM
  - NPM VM
  - Replica VMs (LOG Server,ePO)
- Centralized NAS Server (Backup)
- CS Thin Client.

L3.2 Network Switch is also part of the zone, please add

Cybersecurity Zone VLANs:

#	VLAN Name	VLAN Members
1	CS_VHOST	CS Virtualization Host Server
2	CS_SRV	Cybersecurity Servers
3	CS_STORE	Backup Storage Servers
4	CS_UNUSED	Unused Switch Ports

General

8.2.2 Control System Zone

The function of this zone is to segregate the DCS Systems from different zones (3rd Party systems via L1 Firewall, Schneider SIS/FGS Systems via ACL and Cybersecurity Zone via L3 ICSS Firewall)

Control System Zone contains:

- DCS VM Host Server
- DCS Servers and Workstations (Both Physical & Virtual machines)
- L2 MESH Network Switches
- L3 PIN Network Switches
- L3 VHN Network Switches
- Foxboro Controllers
- NTP Server
- DCS Thin Client

Control System Zone VLANs:

#	VLAN Name	VLAN Members
1	FDCN	DCS Host Servers and Controllers
2	DCS_VHOST	DCS VM Host Servers
3	DCS_SRV	DCS GR, OWS, HIST, NTP Servers, Thin Client, Printers.
4	DCS_ADV_APPS	DCS SYS-ADV
5	DCS_OPC	OPC
6	DCS_UNUSED	Unused Switch Ports
7	DCS_VHN	DCS Virtual Host Servers

General

9 NETWORK SWITCH HARDENING

9.1 Switch security hardening (VHN/PIN/CS)

Also include the configuration method, software name, installed node name and location.
RBAC details

The following configurations will be applied for the network switches:

- Upgrade firmware to the latest qualified version.
- Configure the IP Address, Name, Location, Contact.
- Default admin and user accounts deleted.
- New two Admin accounts will be created, with superuser access.
- Configure Radius authentication.
- WebView disabled.
- All ports deleted from the “default” VLAN.
- Default VLAN 1 to be shutdown.
- Add a Logon Banner.
  - WARNING: This switch / network has restricted access for KNPC authorized Personal only. This system may be monitored as permitted by law. Unauthorized use can result in criminal prosecution, termination or other actions. By proceeding with this login, you are acknowledging that you have authorization to access this switch CLI."
- Discovery Protocols disabled.
- Telnet disabled.
- SSH enabled.
- Number of allowed concurrent session: 3.
- Configure account lockout enable
- Configure max-login-attempts 5.
- Configure lockout-time 15 minutes
- Ports rate limit flood broadcast & multicast is enabled.
- IP Security anomaly Protection Enabled
- Unused ports disabled.
- Clear SNMP community names.
- Password Policy
  - Minimum password length 12 characters.
  - Maximum password age 180 Days.
  - lockout-on-login-failures ON.
  - Auto idle logout to 5 minutes.
- Time will be synchronized from PDC/SDC server.
- Logging settings.
  - Enabling commands line logging history.
  - Config log forwarding to log servers in CS zone.

D

General

9.2 Mesh switches security hardening.

Foxboro DCS Switch Configurator Application Software (SCAS) is the only approved network configurator tool for L2 MESH switches configuration. SCAS 4.3 or latest will be utilized for firmware upgrade and configuration of the switches. Brief details of configuration shown below:

Also include the installed node name and location. RBAC details to SCAS

- Configure the IP Address, Name, Location, Contact
- Default admin and user accounts deleted.
- New Admin accounts will be created.
- VLAN 2 (Only) Enabled for MESH network.
- SNTP enabled for Time Synchronization from Master timekeeper in DCS network.
- Syslog server configured to RMPXIQ DCS Server for monitoring of all L2 MESH switches.
- Enhanced Loop Protection algorithm deployed in addition to standard RSTP.
- Cisco/Extreme Discovery Protocols disabled.
- IP Security anomaly Protection Enabled
- Ports rate limit flood broadcast & multicast is enabled.
- Telnet disabled.
- SSH disabled.
- WebView disabled.
- Unused ports disabled.
- Add a Logon Banner.
  "WARNING: This switch / network has restricted access for Foxboro DCS Control Network personal use only. This system may be monitored as permitted by law. Unauthorized use can result in criminal prosecution, termination or other actions. By proceeding with this login, you are acknowledging that you have authorization to access this switch CLI."
- Password Policy
  - Minimum password length 12 characters.
  - Maximum password age 90 Days.
  - lockout-on-login-failures ON.
  - Lockout period time to 15 minutes (After the configured duration elapses a disabled account is reenabled automatically)

D

General

10 NETWORK FIREWALL HARDENING

This section describes the configuration settings, and the baseline that will be applied to Fortinet Firewalls.

10.1 FortiGate Firewalls

D

Firewall security hardening.

The following security enhancement practice is applicable for the ICSS firewalls:

Also include the configuration management platform, software name & installed node name and its location.
RBAC details accessing the management platform

- Firmware is updated to the latest qualified version.
- Create new two Administrators accounts.
- Enable Radius for authentication.
- Set the hostname as per asset list.
- Disable unused network interface ports.
- Remove the default IP addresses from interfaces.
- Enable strong encryption.
- Disable auto USB installation and configuration.
- Set NTP to sync from Primary & Secondary Domains Controllers.
- Restrict management to trusted host CS EWS.
- Set SNMP v3 to send messages to the NPM Server.
- Set the warning banner that is displayed before credentials being accepted.
- Set SSH & HTTPS connection-limit restrictions to 3.
- Disable insecure or unnecessary access services:
  - telnet.
  - redirect HTTP GUI logins to HTTPS.
  - LLDP.
  - FMG-Access.
- Configure password policy.
  - Minimum length 12 characters
  - Passwords expire enabled.
  - Passwords expire every 180 days.
  - Reuse-password disabled.
- Set idle timeout values for all logins to 5 minutes.
- Set login attempt limit to 5.
- Set login block time 900 sec.
- Install the latest security signatures updates.
- Disable maintainer account.
- Disable sending traffic to external FortiGuard servers.

General

- Deny all policy by default is enabled and visible.

IPS Configuration

The IPS engine uses protocol decoders to identify each protocol appearing in the traffic, Once the protocol decoders separate the network traffic by protocol, the IPS engine examines the network traffic for the attack signatures.

The following IPS settings will be applied to all firewalls.

- IPS anomaly mode is continuous.
- IPS feature is enabled.
- IPS Inspection mode set to Flow-Based.
- IPS will utilize signature-based defense technique.
- IPS security profile enabled on every firewall policy.

Application control

IPS sensor (SE-IPS-SENSOR) profile will be created on all firewalls to scan all the traffic against filtering criteria starting from critical to medium with action is set to Block detected malicious traffic.

Application control technologies detect and act against network traffic based on the application that generated the traffic. Application control uses protocol decoders with signatures that analyze network traffic to detect application traffic, even if the traffic uses nonstandard ports or protocols.

Application control profiles

#	Profile Name	Allowed Applications
1	SE-CS-APP-CTRL	Active directory DNS Trellix Update SNMP_V3 Ping WINDOWS.UPDATE
2	SE-DCS-APP-CTRL	PING DCS Application
3	SE-MGMT-APP-CTRL	MGMT Applications

Firewall Access Rules Policies

Firewall access rules policies and detailed application profiles will be provided after the FAT to the agreed restricted list of persons provided by Company.

Preliminary rules are required

D

Firewall DoS Policy

Denial of Service (DoS) policy examines network traffic arriving at a FortiGate interface for anomalous patterns, which usually indicates an attack.

DoS policies are checked before security policies, preventing attacks from triggering more resource intensive security protection and slowing down the FortiGate.

DoS anomalies

Predefined sensors are setup for specific anomalous traffic patterns.

Anomaly	Description	Recommended Threshold
tcp_syn_flood	If the SYN packet rate of new TCP connections, including retransmission, to one destination IP address exceeds the configured threshold value, the action is executed.	2000 packets per second.
tcp_port_scan	If the SYN packet rate of new TCP connections, including retransmission, from one source IP address exceeds the configured threshold value, the action is executed.	1000 packets per second.
tcp_src_session	If the number of concurrent TCP connections from one source IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
tcp_dst_session	If the number of concurrent TCP connections to one destination IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
udp_flood	If the UDP traffic to one destination IP address exceeds the configured threshold value, the action is executed.	2000 packets per second.
udp_scan	If the UDP sessions setup rate originating from one source IP address exceeds the configured threshold value, the action is executed.	2000 sessions per second.
udp_src_session	If the number of concurrent UDP connections from one source IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
udp_dst_session	If the number of concurrent UDP connections to one destination IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
icmp_flood	If the number of ICMP packets sent to one destination IP address exceeds the configured threshold value, the action is executed.	250 packets per second.
icmp_sweep	If the ICMP sessions setup rate originating from one source IP address exceeds the configured threshold value, the action is executed.	100 sessions per second.

General

Anomaly	Description	Recommended Threshold
icmp_src_session	If the number of concurrent ICMP connections from one source IP address exceeds the configured threshold value, the action is executed.	300 concurrent sessions
icmp_dst_session	If the number of concurrent ICMP connections to one destination IP address exceeds the configured threshold value, the action is executed.	1000 concurrent sessions
ip_src_session	If the number of concurrent IP connections from one source IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
ip_dst_session	If the number of concurrent IP connections to one destination IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions.
sctp_flood	If the number of SCTP packets sent to one destination IP address exceeds the configured threshold value, the action is executed.	2000 packets per second
sctp_scan	If the number of SCTP sessions originating from one source IP address exceeds the configured threshold value, the action is executed.	1000 packets per second
sctp_src_session	If the number of concurrent SCTP connections from one source IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions
sctp_dst_session	If the number of concurrent SCTP connections to one destination IP address exceeds the configured threshold value, the action is executed.	5000 concurrent sessions

Logging Configuration

The logs settings will be configured to forward all captured logs to the Log Management server located in the Cybersecurity Zone. The log severity will be set to Information.

- Log all user events.
- Log all violation traffic.
- Log all security events on the firewall policies.
- Log all system events.
- Log to the internal disk when applicable.
- Log all allowed traffic.

Include encryption enforcement. Which protocol is used to forward logs from devices to the Log Management server, and does it enforce TLS encryption? include the details

Firewalls Updates

Fortinet releases signature updates frequently, it is recommended to regularly update the IPS and Application control signatures.

Fortinet updates can be obtained from Fortinet support website https://support.fortinet.com/.

Include the patch Updating process

10.2 ConneXium Firewalls

Also include the configuration management platform details & installed node, Location details. RBAC details for accessing management platform

- Firmware is updated to the latest qualified version.
- Create new two Administrators accounts.
- Set the hostname as per asset list.
- Disable insecure or unnecessary access services:
  - telnet.
  - HTTP
  - LLDP.
- Configure password policy.
  - Minimum length 12 characters
  - Passwords expire enabled.
  - Passwords expire every 180 days.
- Set idle timeout values for all logins to 5 minutes.
- Deny all by default for firewalls.
- USB Port disabled

D

General

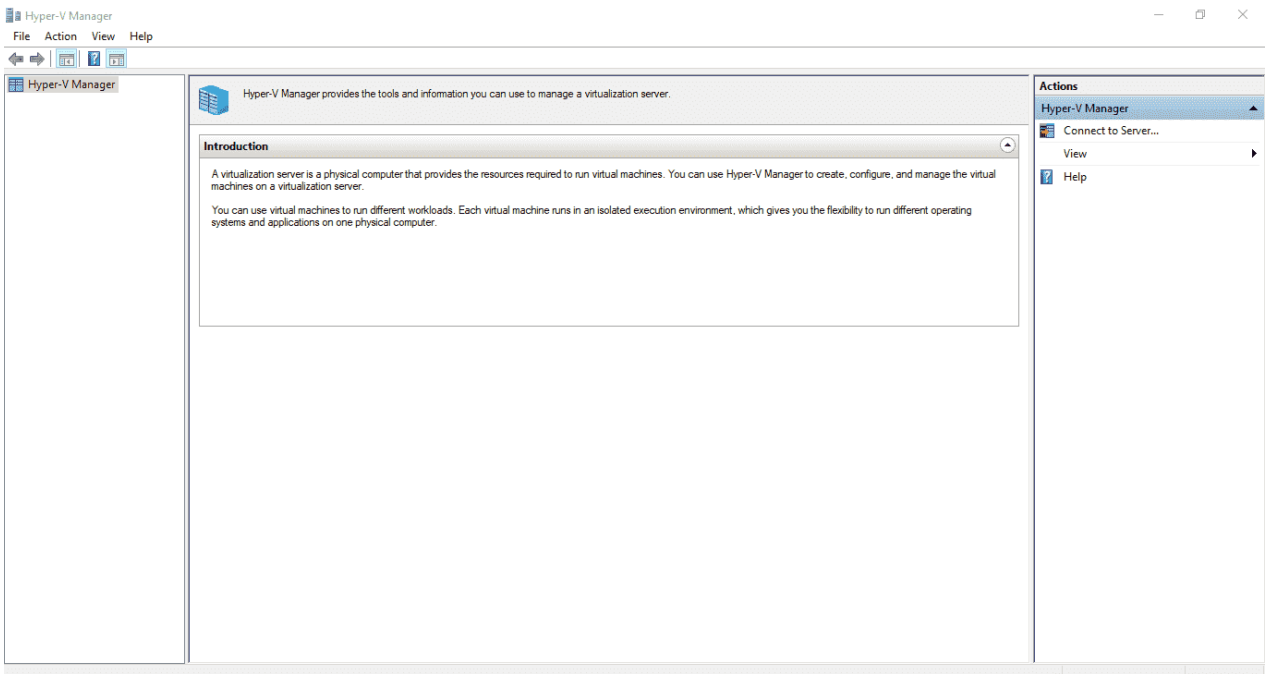
11 CENTRALIZED VIRTUALIZATION MANAGEMENT FOR WINDOWS SERVER 2022

The CVM system is governed by a set of group policies. user groups and organization units. These policies are applied onto V95 virtualization hosts that participate in the CVM system.

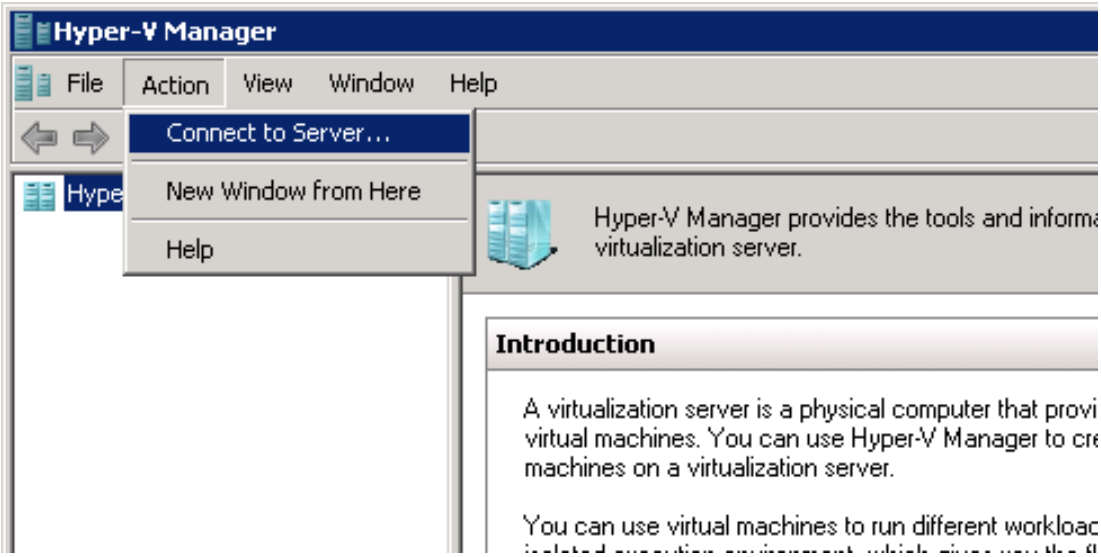
The Foxboro Domain controller (RMPPDC, RMPSDC) will be used to install the CVM Group policies see section 12.4.5; The CVM related objects are added under a separate “Schneider Electric” OU. Therefore, adding these structures does not have any impact on the functionality of the users/computers/ policies of the existing domain. The “Schneider Electric” OU has an inheritance block in order to help prevent the policies of the existing domain being applied on the CVM V95 hosts.

11.1 Hyper-V Manager

To open Hyper-V Manager go to Start Menu and navigating to Administrative Tools, click on Hyper-V Manager:



Once Hyper-V Manager has loaded, if not already connected, you will need to connect to a host:


Hyper-V Manager
File
Action
View
Window
Help
Connect to Server...
New Window from Here
Help
Hyper-V Manager provides the tools and informa
virtualization server.
Introduction
A virtualization server is a physical computer that provi
virtual machines. You can use Hyper-V Manager to cre
machines on a virtualization server.
You can use virtual machines to run different workloac

General

11.2 Cybersecurity Virtual Machines

The following virtual machines are deployed on the cybersecurity server RMCSV1.

#	VIRTUAL MACHINE	CPU	MEMORY	STORAGE	OPERATING SYSTEM	TECHNOLOGY	HOSTED/ REPLICA
1	Primary domain controller + NPS (RMPPDC)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Active directory and RADIUS	Hosted
2	Log Server (RMPLOG)	v4	32	1.2 TB	Microsoft Windows Server 2022 standard	Centralized log server	Hosted
3	Endpoint Protection (RMPEPO)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Endpoint protection	Hosted
4	WSUS downstream (RMWSUS)	v4	32	600 GB	Microsoft Windows Server 2022 standard	Windows patch management	Replica
5	Network performance monitoring. (RMPNPM)	v4	32	600 GB	Microsoft Windows Server 2022 standard	Network performance monitoring	Replica
6	Enterprise certificate authority (RMPECA)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Certificate authority	Replica
7	Enterprise certificate authority (RMPECA2)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Certificate authority (Offline CA)	Replica

D

General

The following virtual machines are deployed on the cybersecurity server RMCSV2.

#	VIRTUAL MACHINE	CPU	MEMORY	STORAGE	OPERATING SYSTEM	TECHNOLOGY	HOSTED/ REPLICA
1	Secondary domain controller + NPS (RMPSDC)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Active directory and Radius	Hosted
2	WSUS downstream (RMWSUS)	v4	32	600 GB	Microsoft Windows Server 2022 standard	Windows patch management	Hosted
3	Network performance monitoring. (RMPNPM)	v4	32	600 GB	Microsoft Windows Server 2022 standard	Network performance monitoring	Hosted
4	Enterprise certificate authority (RMPECA)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Certificate authority	Hosted
5	Log Server (RMPLOG)	v4	32	1.2 TB	Microsoft Windows Server 2022 standard	Centralized log server	Replica
6	Endpoint Protection (RMPEPO)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Endpoint protection	Replica
7	Enterprise certificate authority (RMPECA2)	v4	32	300 GB	Microsoft Windows Server 2022 standard	Certificate authority (Offline CA)	Hosted

D

General

11.3 Virtual Host Server Firewalls

Name	Description	Program	Local port	ICMP settings	Remote scope	Profile	Service	Allow edge traversal	Group
Core Networking - Destination Unreachable Fragmentation Needed (ICMPv4-In)	Destination Unreachable Fragmentation Needed error messages are sent from any node that a packet traverses which is unable to forward the packet because fragmentation was needed and the don't fragment bit was set.	System	Any	type 3:code 4	Any	All	All programs and services	FALSE	Core Networking
Core Networking - IPHTTPS (TCP-In)	Inbound TCP rule to allow IPHTTPS tunneling technology to provide connectivity across HTTP proxies and firewalls.	System	IPTLSIn, IPHTTP SIn	Any	Any	All	All programs and services	FALSE	Core Networking
File and Printer Sharing (NB-Session-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Session Service connections. [TCP 139]	System	139	Any	Any	Domain	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (SMB-In)	Inbound rule for File and Printer Sharing to allow Server Message Block transmission and reception via Named Pipes. [TCP 445]	System	445	Any	Any	Domain	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (NB-Name-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Name Resolution. [UDP 137]	System	137	Any	Any	Domain	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (NB-Datagram-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Datagram transmission and reception. [UDP 138]	System	138	Any	Any	Domain	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (Spooler Service - RPC)	Inbound rule for File and Printer Sharing to allow the Print Spooler Service to communicate via TCP/RPC.	%System Root%\ system32\ spoolsv.exe	Dynamic RPC	Any	Any	Domain	Spooler	FALSE	File and Printer Sharing
File and Printer Sharing (Spooler Service - RPC-EPMAP)	Inbound rule for the RPCSS service to allow RPC/TCP traffic for the Spooler Service.	Any	RPC endpoint mapping	Any	Any	Domain	Rpcss	FALSE	File and Printer Sharing
File and Printer Sharing (Echo Request - ICMPv4-In)	Echo Request messages are sent as ping requests to other nodes.	Any	Any	type 8:code any	Any	Domain	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (LLMNR-UDP-In)	Inbound rule for File and Printer Sharing to allow Link Local Multicast Name Resolution. [UDP 5355]	%System Root%\ system32\ svchost.exe	5355	Any	Local subnet	Domain	dnscache	FALSE	File and Printer Sharing

General

Name	Description	Program	Local port	ICMP settings	Remote scope	Profile	Service	Allow edge traversal	Group
Windows Management Instrumentation (DCOM-In)	Inbound rule to allow DCOM traffic for remote Windows Management Instrumentation. [TCP 135]	%SystemRoot%\system32\svchost.exe	135	Any	Any	Domain, Private, Public	rpcss	FALSE	Windows Management Instrumentation (WMI)
Windows Management Instrumentation (WMI-In)	Inbound rule to allow WMI traffic for remote Windows Management Instrumentation. [TCP]	%SystemRoot%\system32\svchost.exe	Any	Any	Any	Domain, Private, Public	winmgmt	FALSE	Windows Management Instrumentation (WMI)
Windows Management Instrumentation (ASync-In)	Inbound rule to allow Asynchronous WMI traffic for remote Windows Management Instrumentation. [TCP]	%systemroot%\system32\wbem\unsecapp.exe	Any	Any	Any	Domain, Private, Public	All programs and services	FALSE	Windows Management Instrumentation (WMI)
@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-212	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-213	%SystemRoot%\system32\svchost.exe	135	Any	Any	All	rpcss	FALSE	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-211
@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-214	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-215	%SystemRoot%\system32\svchost.exe	Any	Any	Any	All	winmgmt	FALSE	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-211
@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-218	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-219	%SystemRoot%\system32\svchost.exe	Any	Any	Any	All	All programs and services	FALSE	@%ProgramFiles%\Hyper-V\SnapInAbout.dll,-211
@%systemroot%\system32\vmms.exe,-211	@%systemroot%\system32\vmms.exe,-212	%SystemRoot%\system32\svchost.exe	135	Any	Any	All	rpcss	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-213	@%systemroot%\system32\vmms.exe,-214	%SystemRoot%\system32\svchost.exe	Any	Any	Any	All	winmgmt	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-217	@%systemroot%\system32\vmms.exe,-218	%systemroot%\system32\wbem\unsecapp.exe	Any	Any	Any	All	All programs and services	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-219	@%systemroot%\system32\vmms.exe,-220	System	RPC endpoint mapping	Any	Any	All	All programs and services	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-223	@%systemroot%\system32\vmms.exe,-224	System	Dynamic RPC	Any	Any	All	All programs and services	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-227	@%systemroot%\system32\vmms.exe,-228	%systemroot%\system32\vmms.exe	6600	Any	Any	All	vmms	FALSE	@%systemroot%\system32\vmms.exe,-210
@%systemroot%\system32\vmms.exe,-229	@%systemroot%\system32\vmms.exe,-230	%systemroot%\system32\vmms.exe	2179	Any	Any	All	vmms	FALSE	@%systemroot%\system32\vmms.exe,-210

General

Name	Description	Program	Local port	ICMP settings	Remote scope	Profile	Service	Allow edge traversal	Group
SNMP Service (UDP In)	Inbound rule for the Simple Network Management Protocol (SNMP) Service to allow SNMP traffic. [UDP 161]	%SystemRoot%\system32\snmp.exe	161	Any	Local subnet	Private, Public	SNMP	FALSE	SNMP Service
SNMP Service (UDP In)	Inbound rule for the Simple Network Management Protocol (SNMP) Service to allow SNMP traffic. [UDP 161]	%SystemRoot%\system32\snmp.exe	161	Any	Any	Domain	SNMP	FALSE	SNMP Service
Remote Desktop Services (RPC)	Inbound rule to allow Remote Desktop Services to be remotely managed via RPC/TCP traffic	%systemroot%\system32\svchost.exe	Dynamic RPC	Any	Any	All	TermService	FALSE	Remote Desktop Services
Remote Desktop Services (RPC-EPMAP)	Inbound rule for the RPCSS service to allow RPC/TCP traffic for Remote Desktop Services	%systemroot%\system32\svchost.exe	RPC endpoint mapping	Any	Any	All	RPCSS	FALSE	Remote Desktop Services
Remote Desktop Services (NP-In)	Inbound rule to allow Remote Desktop Services to be remotely managed over Named Pipes.	System	445	Any	Any	All	All programs and services	FALSE	Remote Desktop Services
Remote Desktop Services - WMI (DCOM-In)	Inbound rule to allow DCOM traffic for remote WMI management of Remote Desktop Services. [TCP 135]	%systemroot%\system32\svchost.exe	135	Any	Any	All	RPCSS	FALSE	Remote Desktop Services
Remote Desktop Services - WMI (TCP-In)	Inbound rule for WMI management of Remote Desktop Services	%systemroot%\system32\svchost.exe	Dynamic RPC	Any	Any	All	winmgmt	FALSE	Remote Desktop Services
Remote Desktop Services - User Mode (TCP-In)	Inbound rule for the Remote Desktop service to allow RDP traffic. [TCP 3389]	%SystemRoot%\system32\svchost.exe	3389	Any	Any	All	termservice	FALSE	Remote Desktop Services
Remote Desktop Services - User Mode (UDP-In)	Inbound rule for the Remote Desktop service to allow RDP traffic. [UDP 3389]	%SystemRoot%\system32\svchost.exe	3389	Any	Any	All	termservice	FALSE	Remote Desktop Services
Remote Desktop Services - Shadow (TCP-In)	Inbound rule for the Remote Desktop service to allow shadowing of an existing Remote Desktop session. (TCP-In)	%SystemRoot%\system32\RdpSa.exe	Any	Any	Any	All	All programs and services	TRUE	Remote Desktop Services
File Server Remote Management (WMI-In)	Inbound rule to allow WMI traffic to manage the File Services role.	%systemroot%\system32\svchost.exe	Dynamic RPC	Any	Any	All	Winmgmt	FALSE	File Server Remote Management
File Server Remote Management (DCOM-In)	Inbound rule to allow DCOM traffic to manage the File Services role.	%systemroot%\system32\svchost.exe	135	Any	Any	All	RPCSS	FALSE	File Server Remote Management
File Server Remote Management (SMB-In)	Inbound rule to allow SMB traffic to manage the File Services role.	System	445	Any	Any	All	All programs and services	FALSE	File Server Remote Management

General

Name	Description	Program	Local port	ICMP settings	Remote scope	Profile	Service	Allow edge traversal	Group
File and Printer Sharing (LLMNR-UDP-In)	Inbound rule for File and Printer Sharing to allow Link Local Multicast Name Resolution. [UDP 5355]	%SystemRoot%\system32\svchost.exe	5355	Any	Local subnet	Private	dnscache	FALSE	File and Printer Sharing
File and Printer Sharing (Echo Request - ICMPv4-In)	Echo Request messages are sent as ping requests to other nodes.	Any	Any	type 8:code any	Any	Private	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (Spooler Service - RPC-EPMAP)	Inbound rule for the RPCSS service to allow RPC/TCP traffic for the Spooler Service.	Any	RPC endpoint mapping	Any	Any	Private	Rpcss	FALSE	File and Printer Sharing
File and Printer Sharing (Spooler Service - RPC)	Inbound rule for File and Printer Sharing to allow the Print Spooler Service to communicate via TCP/RPC.	%SystemRoot%\system32\spoolsv.exe	Dynamic RPC	Any	Any	Private	Spooler	FALSE	File and Printer Sharing
File and Printer Sharing (NB-Datagram-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Datagram transmission and reception. [UDP 138]	System	138	Any	Any	Private	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (NB-Name-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Name Resolution. [UDP 137]	System	137	Any	Any	Private	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (SMB-In)	Inbound rule for File and Printer Sharing to allow Server Message Block transmission and reception via Named Pipes. [TCP 445]	System	445	Any	Any	Private	All programs and services	FALSE	File and Printer Sharing
File and Printer Sharing (NB-Session-In)	Inbound rule for File and Printer Sharing to allow NetBIOS Session Service connections. [TCP 139]	System	139	Any	Any	Private	All programs and services	FALSE	File and Printer Sharing
@%systemroot%\system32\vmms.exe,-231	@%systemroot%\system32\vmms.exe,-232	System	80	Any	Any	All	All programs and services	FALSE	@%systemroot%\system32\vmms.exe,-251
macmnsvc		C:\Program Files\McAfee\Agent\macmnsvc.exe	Any	Any	Any	Domain	All programs and services	FALSE	
macmnsvc		C:\Program Files\McAfee\Agent\macmnsvc.exe	Any	Any	Any	Domain	All programs and services	FALSE	
VHN_Replication_Inbound_Rule		SYSTEM	18777	Any	Any	All	All programs and services	FALSE	

General

Name	Description	Program	Local port	ICMP settings	Remote scope	Profile	Service	Allow edge traversal	Group
Hyper-V - Live Migration (TCP-In)		Any	6600	Any	Any	Domain, Private	All programs and services	FALSE	
Windows Remote Management (HTTP-In)	Inbound rule for Windows Remote Management via WS-Management. [TCP 5985]	System	5985	Any	Any	Domain, Private	All programs and services	FALSE	Windows Remote Management
Windows Remote Management (HTTPS-In)	Inbound rule for Windows Remote Management via WS-Management. [TCP 5986]	System	5986	Any	Any	Domain, Private	All programs and services	FALSE	

Failover, high availability/ fault tolerance strategies section to be included for Cybersecurity VMs

General

12 DOMAIN CONTROLLERS

12.1 Active Directory Overview

D

Microsoft Windows Active Directory Domain Services (ADDS) provide centralized access management of users and resources from a server defined as a Domain Controller.

Foxboro DCS installs the Active Directory on a Primary Domain Controller during the Control Core Services installation. A set of preconfigured user groups and security policies are installed as part of the Foxboro™ Active Directory. These group policies govern the access control and security posture of the users and computers that are part of the DCS.

Domain controllers store information, including security credentials and login information for all users' accounts and resources within the domain in central database. Domain controllers allow a central access point for configuring and administering a secure network.

Foxboro DCS installed with the Enterprise Edition employs the use of Microsoft Active Directory.

A central and vital component of an Active Directory environment is the Domain Controller (DC).

Only one Domain Controller can take on the role of the "primary" Domain Controller (PDC) at a particular time. As the DC is vital component additional "secondary" Domain Controller (SDC) is considered which can take over the primary role if the current primary Domain Controller experiences a detected failure.

The new Domain Name to be defined in the form "RMP.local" from which the full computer name FQDN must be formed as the following structure: "KNPC.RMP.local."

Note: Domain Name can be changed with the company name preference.

12.2 Overview of Domain Controllers Roles

12.2.1 Operational Setup

- Primary Domain Controller (PDC):
    - Hosts all FSMO (Flexible Single Master Operations) roles, especially the PDC Emulator role.
    - Responsible for time synchronization, password changes, and acting as the preferred DC for clients.
    - Runs DNS and Global Catalog services for domain-wide authentication.
- Secondary Domain Controller (SDC):
    - Serves as a backup DC and holds a full read/write copy of the AD database.
    - Runs DNS and Global Catalog services for redundancy.
    - Participates in the same replication topology as the PDC.

Both DCs are configured as Global Catalog Servers and DNS Servers for fault tolerance and faster logon services.

12.2.2 Replication Configuration

- Replication Type: Multi-Master Replication
  - All DCs replicate changes to each other in a multi-master fashion using Active Directory Replication Services (ADRS).
  - Changes to objects (e.g., user accounts, group policies) can be made on any DC and are propagated to others.
- Replication Schedule:
  - Intra-Site Replication (within same site): Occurs every 15 seconds by default.
- Transport:
  - Uses RPC over IP for intra-site replication.
- Conflict Resolution:
  - Uses USNs (Update Sequence Numbers) and a last-writer-wins strategy to resolve replication conflicts.

12.2.3 Failover Process

In the event of the Primary DC failure, the following failover process ensures continued domain functionality:

- Authentication and Authorization:
  - Clients are automatically redirected to the Secondary DC for login and resource access.
  - The SDC responds to LDAP, Kerberos, and DNS requests without manual intervention.
- FSMO Role Failover:
  - If the Primary DC holding FSMO roles is unavailable:
  - Short-term: AD functions continue, but certain tasks (e.g., password lockout processing, RID allocation) may degrade.
  - Long-term: FSMO roles should be seized using PowerShell or NTDSUTIL if recovery is not expected.
- DNS Failover:
  - Clients use multiple DNS servers (e.g., IPs of both PDC and SDC) in their NIC settings.
  - If one DNS server is down, the client automatically queries the other.

12.3 Active Directory Structure

The Active Directory technology was designed to work for small systems up to very large enterprise systems. Its structure allows for organizing computers and users into logical groupings at various hierarchical levels.

At the lowest level are the individual workstations and users. These can be grouped into domains. Multiple domains can be grouped into a tree and multiple trees can belong to a forest (the highest level).

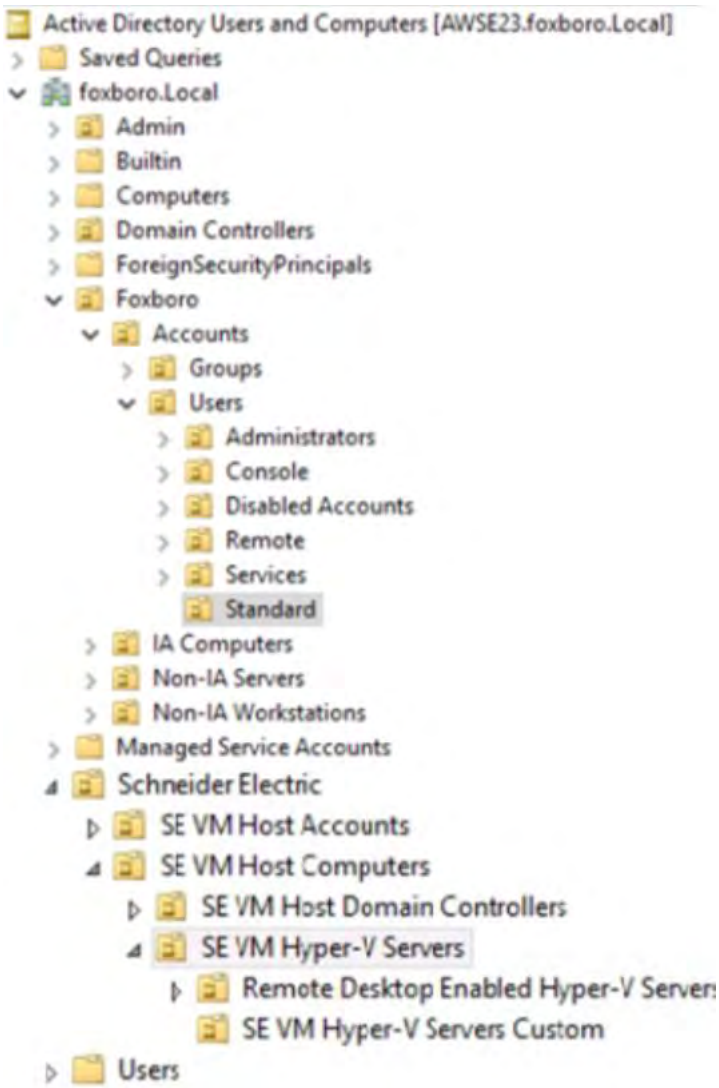
General

12.3.1 Organizational Units (OU)

There are also "Organizational Units" and "sites." Organizational Units (OU) allow to set up logical divisions within a domain as per zones defined, similar to sub-domains.

12.3.2 Organizational Unit Structure for CCS v9.8

The Control Core Services v9.8 OUs showing below.



General

12.3.3 Customized Organization Unit

- DCS Server and Workstations will be placed in dedicated OUs "IA Computers" to receive their own security policies, independently from other OU.
- Cybersecurity Servers will be placed in one dedicated OU "Cybersecurity Servers" under the "non-IA Servers" to receive their own security policies, independently from other OU.

12.3.4 Security Groups

The concept of "security groups" is also present in the Active Directory structure. Like an OU, a security group can include users and workstations. However, there is a difference.

OUs act as containers of objects (such as users and workstations); whereas security groups are a collection of attributes that can be assigned to an object. Each computer or user can be a member of multiple Security Groups.

NOTE: A user account can be in only one OU but can be a member of any number of security groups.

12.3.5 Security Group Policies and Group Policy Objects

Group policies are applied to OUs, domains, or sites. Group policies provide central administration of settings that can be applied to multiple users and workstations. Group policy determines which users have permission to perform certain actions, such as shutting down a workstation or having access to the Task Manager.

Group policies can manage computer-specific settings, user-specific settings, or both. Computer policies are applied at boot time. User policies take effect when a user logon occurs. Domain based group policies (other than folder redirection and software installation) are not only applied at logon time, but also reapply themselves periodically to keep current with any changes.

Group Policy refresh interval specific for Domain Controllers is every 5 minutes and a different refresh interval of 90 minutes is used for all other computers. These refresh intervals are controlled via group policy.

Group policies are processed in a hierarchical order. For example, Local Security Policy is first, then site- level policies, then domain-level policies, and then OU-level policies. Users and workstations that are both in a domain and an OU receive settings both from the domain-level policy (Base Policy) and from the OU level policy. If the same policy is configured at multiple levels, the behavior` depends on how the policy is configured at the higher level. For example, it is possible to set a "No Override" option that prevents a policy from being overridden at a lower level. Otherwise, normally the lower-level policy (the last one applied) would win.

General

12.3.6 Security Users and Security Groups for CCS v9.8

The table shows the members of the Active Directory containers as configured by the Control Core Services v9.8 installation. The members include security groups and user accounts. The table shows the default names for these users, such as "IAInstaller" and "KNDomainAdmin."

Active Directory Container	Security Group
Accounts > Groups > Administration	Cert Publishers DnsAdmins DnsUpdateProxy Domain Admins Domain Computers Domain Controllers Domain Guests Domain Users Enterprise Admins Group Policy Creator Owners RAS and IAS Servers Schema Admins OT Security
Accounts > Groups > IA Groups	Enable Screen Saver Exceed_Users IA FoxView Access IA Installer IA Plant Admins IA Plant Engineers IA Plant Operators IA Plant View Only IA System Access
Accounts > Groups > Remote	IA Remote Access
Accounts > Groups > Services	Foxboro Services SE Services
Accounts > Groups > Standard	<empty>
Accounts > Users > Administrators	Administrator (U) (Disabled and SAM acct name renamed as IAManager) IAInstaller (U) KNDomainAdmin (U) KNDomainAdmin
Accounts > Users > Services	NSPservice (U)
Accounts > Users > Console	<customer-created users>

General

Active Directory Container	Security Group
Accounts > Users > Disabled Accounts	Guest (Renamed as GuestNotAllowed)
Accounts > Users > Standard	<customer-created users>
BUILTIN\Administrators	Administrator[b] (U) Domain Admins Enterprise Admins
BUILTIN\Users	Authenticated Users Domain Users Interactive
Domain Admins	KNDomainAdmin (U) Administrator[b] (U) OT Security
Enable Screen Saver	IA Plant Admins IA Plant Engineers
Exceed_Users	IA Plant Admins IA Plant Engineers IA Plant Operators IA FoxView Access
IA FoxView Access	IA Plant Admins IA Plant Engineers IA Plant Operators IA Plant View Only
IA Installer	IAInstaller (U)
IA Remote Access	<customer-created users>
IA System Access	IA Plant Admins IA Plant Engineers IA Plant Operators
IA Plant Admins	<customer-created users>
IA Plant Engineers	<customer-created users>
IA Plant Operators	<customer-created users>
IA Plant View Only	<customer-created users>

(a) These are groups unless designated as a user account by "(U)".

(b) The built-in "Administrator" is renamed as IAManager and disabled.

General

Hypervisor Admin Accounts	
Active Directory Container	**Security Group**
Schneider Electric>SE VMHost Accounts>Groups	VMHostAdmins
Foxboro>Accounts>Administrators	SE (U)
Schneider Electric>SE VMHost Accounts>Users	VHAdmin (U)
Schneider Electric>SE VMHost Accounts>Users	VHEngineer (U)

12.4 Group Policy Management

Group policies have two sections:

- Computer Configuration.
- User Configuration.

The Foxboro Plant Admins, Plant Engineers, Plant Operators, and Plant View Only group policies have the User Configuration section enabled and the Computer Configuration section disabled.

The table shows which of these sections are enabled or disabled by default for the group policies shipped by Schneider Electric.

Group Policy	Computer Configuration	User Configuration
Foxboro Base Non-CCS v1.0	Enabled	Disabled
Foxboro Base Policy v1.0	Enabled	Disabled
Foxboro CNI Computer Policy v1.0	Enabled	Disabled
Foxboro 2022 Domain Controllers Policy v1.0	Enabled	Enabled
Foxboro Domain Policy v2.0	Enabled	Disabled
Foxboro Enhanced Interactive Logon Banner ON v1.0	Enabled	Disabled
Foxboro Enhanced Screen Saver Enabled Filtered v1.0	Disabled	Enabled
Foxboro FoxView Environments v1.0	Enabled	Disabled
Foxboro CCS Computers v2.0	Enabled	Disabled
Foxboro CCS Remote Desktop Servers v2.0	Enabled	Disabled
Foxboro CCS Users Filtered v1.0	Disabled	Enabled
Foxboro Interactive Logon Banner OFF v1.0	Enabled	Disabled
Foxboro Plant Admins Filtered v1.0	Disabled	Enabled
Foxboro Plant Engineers Filtered v1.0	Disabled	Enabled
Foxboro Plant Operators Filtered v1.0	Disabled	Enabled
Foxboro Plant View Only Filtered v1.0	Disabled	Enabled
Foxboro Server 2022 Member Server Security Compliance	Enabled	Disabled

General

Group Policy	Computer Configuration	User Configuration
v1.0		
Foxboro Win10 Computer Security Compliance v1.0	Enabled	Disabled
Foxboro Thin Client Remote Desktop Access v1.0	Enabled	Disabled
Foxboro Code Signing Certificates v2.0	Enabled	Disabled
(a) The user configuration settings though configured, will not be applied at the user level.		

Below table shows policies for the Hypervisor Server (V95 VM Host Server):

Group Policy	Computer Configuration	User Configuration
Virt IE 11 Merged Baseline 2.0	Enabled	Enabled
SE Server 2022 Member Server Security Compliance v1.0	Enabled	Disabled
Virt Hyper-V Merged Baseline 2.0	Enabled	Enabled
Virt Hyper-V Security Services 2.0	Enabled	Disabled
Virt SE Restricted Group Policy for non-SE CVM Domain v1.0	Enabled	Enabled
VM Host Security Compliance v1.0	Enabled	Disabled
Virt Hyper-V Security RDP Enabled 2.0	Enabled	Disabled
Virt Remote Access Settings for V95 Host Enabled 2.0	Disabled	Disabled

Below table shows custom policies for cybersecurity:

Group Policy	Computer Configuration	User Configuration
SE Windows Event Forwarding WEF Client v1.0	Enabled	Disabled
SE Bginfo Policy v1.0	Enabled	Disabled
SE NTP Policy for Domain Controllers v1.0	Enabled	Disabled
SE NTP Policy for Non- IA Computers v1.0	Enabled	Disabled

The User Configuration section allows different group policy settings to be applied based on the logged-on user such as access to shutting down a station, access to the command prompt, and so forth.

When either the Computer Configuration or User Configuration section is disabled, the group policy settings in that section do not get applied.

General

12.4.1 Group Policies Naming Conventions

Schneider Electric-supplied group policies have “Foxboro” at the beginning of their names.

All enhanced-level group policies have the word “Enhanced” in them.

All group policies have their version set to 1.0 for Control Core Services.

Including “Filtered” in the name indicates that the group policy applies to specific users rather than to the default of all “Authenticated Users.”

If you create any custom group polices and you are unable to retain these naming conventions, it is recommended that you prefix its name with “Custom” (to indicate a custom security policy) to the new policy - for example, “Custom Domain Controllers Policy v1.0.” This will make it easier to keep track of which policies were shipped by Schneider Electric and which were customized after the initial software installation.

12.4.2 Group Base-Level and Enhanced-Level Security Group Policies

The Control Core Services v9.8 installation creates two sets of group policies. These policies are:

- Base-level security group policies - provide the minimal or mandatory level of security settings which are sufficient for the needs of most users:

    - Foxboro Base Non-CCS v1.0
    - Foxboro Base Policy v1.0
    - Foxboro 2022 Domain Controllers Policy v1.0
    - Foxboro Domain Policy v2.0
    - Foxboro FoxView Environments v1.0
    - Foxboro CCS Computers v2.0
    - Foxboro CCS Remote Desktop Servers v2.0
    - Foxboro CCS Users Filtered v1.0
    - Foxboro Interactive Logon Banner OFF v1.0
    - Foxboro Server 2016 Member Server Security Compliance v1.0
    - Foxboro Server 2022 Member Server Security Compliance v1.0
    - Foxboro Win10 Computer Security Compliance v1.0
    - Foxboro Win10 21H2 Computer Security Compliance v1.0
    - Foxboro ON Control Network Only Policy v1.0
    - Foxboro Plant Admins Filtered v1.0
    - Foxboro Plant Engineers Filtered v1.0
    - Foxboro Plant Operators Filtered v1.0
    - Foxboro Plant View Only Filtered v1.0
    - Foxboro Thin Client Remote Desktop Access v1.0

General

- Enhanced-level security group policies - provide additional security settings that can be optionally installed for systems which require these enhanced settings :
  - Foxboro Enhanced Interactive Logon Banner ON v1.0
  - Foxboro Enhanced Screen Saver Enabled Filtered v1.0

12.4.3 Base-Level Group Policy Descriptions

Foxboro Base Non-CCS v1.0

This is a sample group policy that can be used in place of the default Microsoft policy "Default Domain" for non-Control Core Services workstations.
This group policy modified to meet the security requirements for non-Control Core Services workstations. For example, EPO, WSUS, and Backup servers.

Foxboro Base Policy v1.0

This policy is linked at the base of the Foxboro OU to provide group policy settings common to the sub-containers hierarchically below the Foxboro OU.

Foxboro 2022 Domain Controllers Policy v1.0

This policy is used in place of the default Microsoft policy "Default Domain". This group policy sets the defaults for the domain. It must be the only group policy used for controlling Password Policy settings. It also includes:

- Account Policies settings.
- Local Policies settings

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. If changes are needed, create a new group policy. **Failure to follow these instructions can result in data loss.**

General

Foxboro Domain Policy v2.0

This policy is used in place of the default Microsoft policy "Default Domain". This group policy sets the defaults for the domain. It must be the only group policy used for controlling Password Policy settings. It also includes:

- Account Policies settings.
- Local Policies settings

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. If changes are needed, create a new group policy. **Failure to follow these instructions can result in data loss.**

Foxboro FoxView Environments v1.0

This policy provides a way to control FoxView environments based on the logged-on users' role.

Foxboro CCS Computers v2.0

This policy is used to set the computer policy settings for all workstations with Control Core Services v9.8 on the control network (excluding domain controllers).

NOTICE
POTENTIAL DATA LOSS Do not modify this group policy, as it sets file permissions on workstations with Control Core Services v9.6. Changing or modifying this group policy may cause Control Core Services v9.6 issues or detected failures. **Failure to follow these instructions can result in data loss.**

Foxboro CCS Remote Desktop Servers v2.0

This policy is used to enable remote sessions. It enables the "Remote Desktop Services" service and sets the needed permissions to allow non-administrator users to remotely access workstations with Control Core Services v9.8 running Windows Server 2022.

This group policy is used in combination with OUs and security groups to configure remote access: Workstations with Control Core Services v9.8 running Windows Server 2022 that will provide Remote Desktop Services must be moved to the "Remote Desktop Servers" OU located under the "IA Computers" OU.

Users requiring remote access must be added to the "IA Remote Access" security group located under the Accounts > Groups > Remote OU.

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. If changes are needed, create a new group policy. **Failure to follow these instructions can result in data loss.**

Foxboro CCS Users Filtered v1.0

This policy is used to set the user policy settings for all Control Core Services v9.8 user accounts.

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. If changes are needed, create a new group policy. **Failure to follow these instructions can result in data loss.**

Foxboro Interactive Logon Banner OFF v1.0

This policy is used to turn off the logon banner. (By default, the logon banner is turned off. However, if the Foxboro Enhanced Interactive Logon Banner ON group policy has been applied at a high-level in the domain and you want to turn it off at a lower-level OU, then this policy can be applied to turn it off.)

This group policy is also applied to the Autologon Consoles OU since the banner text feature cannot be used in conjunction with autologon, as it might delay the autologon function.

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. **Failure to follow these instructions can result in data loss.**

General

Foxboro CCS Users Filtered v1.0

This policy is used to set the user policy settings for all Control Core Services v9.8 user accounts.

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. **Failure to follow these instructions can result in data loss.**

Foxboro Interactive Logon Banner OFF v1.0

This policy is used to turn off the logon banner. (By default, the logon banner is turned off. However, if the Foxboro Enhanced Interactive Logon Banner ON group policy has been applied at a high-level in the domain and you want to turn it off at a lower-level OU, then this policy can be applied to turn it off.)

This group policy is also applied to the Autologon Consoles OU since the banner text feature cannot be used in conjunction with autologon, as it might delay the autologon function.

NOTICE
POTENTIAL DATA LOSS Do not modify this policy. **Failure to follow these instructions can result in data loss.**

Foxboro Server 2022 Member Server Security Compliance v1.0

This policy contains the critical settings that enhances the security of Server 2022 domain client machine and will be applied only on member Server 2022 clients.

Foxboro Win10 Computer Security Compliance v1.0

This policy contains the critical settings that enhances the security of Windows 10 domain client machine, and it will be applied only Windows 10 clients.

Foxboro Plant Admins Filtered v1.0

This policy is used to provide security settings for user accounts that are members of the IA Plant Admins security group.

Since the IA Plant Admins security group is a member of the local Administrators group, it provides access to more Windows features than IA Plant Engineers, e.g., access to registry editing tools.

NOTICE
POTENTIAL DATA LOSS Do not modify this group policy. **Failure to follow these instructions can result in data loss.**

Foxboro Plant Operators Filtered v1.0

This policy is used to provide security settings for user accounts that are members of the IA Plant Operators security group. It locks down the Windows environment.

NOTICE
POTENTIAL DATA LOSS Do not modify this group policy. **Failure to follow these instructions can result in data loss.**

Foxboro Plant View Only Filtered v1.0

This policy is used to provide security settings for user accounts that are members of the IA Plant View Only security group. It locks down the Windows environment and does not allow changes to the process being controlled.

Foxboro Thin Client Remote Desktop Access v1.0

This policy is used to enable a process/user to be able to access the remote desktop using saved login credentials. This policy is typically required by thin clients that need to remote into other servers by saved login credentials on the invoking workstation.

This GPO must be linked to the “Thin Client Accessible Servers” OU under IA Computers > Remote Desktop Servers OU. By default, this GPO is not linked to the “Thin Client Accessible Servers” OU.

NOTICE
POTENTIAL DATA LOSS Do not modify this group policy. **Failure to follow these instructions can result in data loss.**

12.4.4 Group Enhanced-Level Group Policy Descriptions

Foxboro Enhanced Interactive Logon Banner ON v1.0

This policy can be used by customers to turn on the logon banner. (By default, the logon banner is turned off.) If you use this policy, modify it to provide the banner message text and message title that are appropriate for your site.

Foxboro Enhanced Screen Saver Enabled Filtered v1.0

This policy is used to turn on screensavers based on membership of a user in a security group. (By default, screensavers are disabled.)

NOTICE
POTENTIAL DATA LOSS Do not modify this group policy. **Failure to follow these instructions can result in data loss.**

12.4.5 CVM Host Server (V95) Group Policies

Virt IE 11 Merged Baseline 2.1

This policy contains internet explorer 11 settings to enhance security of the V95 windows operating system.

SE Server 2022 Member Server Security Compliance v1.0

This policy contains the critical settings that enhances the security of Server 2022 domain client machine and will be applied only on member Server 2022 clients.

Virt Hyper-V Merged Baseline 2.0

This policy is linked at the base of the Schneider Electric OU to provide group policy settings common to the sub-containers hierarchically below the Schneider Electric OU.

Virt Hyper-V Security Services 2.0

This policy contains the critical settings for the V95 operating system services.

Virt SE Restricted Group Policy for non-SE CVM Domain v1.0

This policy contains the critical settings for the built-in restricted group.

VM Host Security Compliance v1.0

This policy contains the critical settings that enhances the security for the v95 operating systems, in addition to the auditing and user right assignment.

Virt Hyper-V Security RDP Enabled 2.0

This policy contains the settings to enable the RDP services for the V95 host servers.

Virt Remote Access Settings for V95 Host Enabled 2.0

This policy contains the settings to allow the RDP to the V95 host servers from the specific user groups.

D

12.5 Customized Group Policies

12.5.1 Foxboro Server 2022 Member Server Security Compliance v1.1

The following security settings will be enabled in addition to the Foxboro security baseline.

Setting	Value
Shutdown: Clear virtual memory pagefile	Enabled
Turn On Virtualization Based Security	Enabled
Platform Security Level	Secure Boot with DMA Protection
Credential Guard Configuration	Enabled with UEFI lock
Debug Programs	Administrators
'Configure LSASS to run as a protected process'	Enabled

12.5.2 Foxboro Win10 21H2 Computer Security Compliance v1.1

The following security settings will be enabled in addition to the Foxboro security baseline.

Setting	Value
Shutdown: Clear virtual memory pagefile	Enabled
Turn On Virtualization Based Security	Enabled
Platform Security Level	Secure Boot with DMA Protection
Credential Guard Configuration	Enabled with UEFI lock
Debug Programs	Remove all unnecessary accounts
'Configure LSASS to run as a protected process'	Enabled

12.5.3 Schneider Electric Windows Event Forwarding WEF Client v1.0

Event Forwarding	Setting
Configure target subscription manager	Server=https://RMPLOG:5986/wsman/SubscriptionManager/WEC,Refresh=60

12.5.4 S Schneider Electric Windows Update Service (WSUS) Policy v1.0

This Policy is used sets Computers setting to configure the windows update service parameters for the WSUS server to all servers, workstation, ThinClient running Microsoft Windows OS.

Setting	Value
Allow Automatic Updates immediate installation	Disabled
Allow non-administrators to receive update notifications	Disabled
Automatic Updates detection frequency	Disabled
Configure Automatic Updates	Enable
Configure automatic updating:	3 – Auto download and notify for install (default setting)
Do not adjust defaults option to 'Install. Updates and Shut Down' in Windowsdialog box	Disabled
Do not display 'Install Updates andShut Down' options in Shut Down Windows Dialog box	Disabled
Enable client-side targeting	Disabled
Specify intranet Microsoft update service location	Enabled
Set the intranet update service for detecting updates	https://RMWSUS:8531
Set the intranet statistics server: (Example: http://IntranetUpd01)	https://RMWSUS:8531
Turn on Software Notifications	Disabled
System Services > Windows Update Services	
NT AUTHORITY\Authenticated Users	Allow: Read
BUILTIN\Administrators	Allow: Full Control
BUILTIN\Server Operators	Allow: Read
BUILTIN\Server Operators	Allow: Start, Stop, Pause, and continue
NT AUTHORITY\SYSTEM	Allow: Read
NT AUTHORITY\SYSTEM	Allow: Start, Stop, Pause, and continue

General

12.5.5 Schneider Electric Bginfo Policy v1.0

This Policy will be defined to deploy Bginfo to all the Domain Computers, Bginfo is used to display several information directly in the background of the computer, which allows user to know at a glance information such as the version of the OS, the IP address or the name of the computer, etc.

12.5.6 Schneider Electric NTP Policy for Domain Controllers v1.0

This Policy is used sets Computers setting to configure the Time Syncing settings for Domain Controllers. The DCS will be set as Client for NTP appliance and as Server for Non-IA Workstation and servers.

12.5.7 Schneider Electric NTP Policy for Non-IA Computers v1.0

This Policy is used sets Computers setting to configure the Time Syncing settings for Non-IA Server & Workstation (Thin Client).

D

12.5.8 Schneider Electric SNMP Enablement for NPM v1.0

This Policy is used sets Computers setting to configure the SNMP settings, community and NPM Server for Servers & Workstation.

Section 12.5.11 SE Credential Guard and LSA Protection v1.0

unable find the above section
Cell J20 from appendix D

12.6 Linking and Filtering Group Policies

Among the configuration options for group policies are:

- Linking operations - in which a group policy is attached (linked) to an Active Directory container, such as organizational unit. When there are multiple policies linked to one container, the “inheritance order” of the links becomes important.
- Filtering operations - in which you can refine how group policies are applied based on specific users or groups as opposed to only the container.

Both of these aspects can be viewed in the Group Policy Management Console tool included with Windows Server 2022.

The table shows how the base-level group policies are linked to Active Directory containers by default.

NOTE: The enhanced-level group policies are not linked by default.

General

Linking operations:

Active Directory Container	Linked Group Policies (in the link order from smallest to largest)
<Top Level of Domain>	Foxboro Domain Policy Foxboro Code Signing Certificates Custom Bginfo Policy v1.0
<Top Level of Foxboro OU>	Foxboro Base Policy
Accounts	Foxboro CCS Users Filtered Foxboro Plant View Only Foxboro Plant Operators Filtered Foxboro Plant Engineers Filtered Foxboro Plant Admins Filtered Foxboro Enhanced Screen Saver Enabled Filtered (optional)
Admin	<no GPOs linked>
Autologon Consoles	Foxboro Interactive Logon Banner OFF
Domain Controllers	Foxboro 2022 Domain Controllers Policy Foxboro ON Control Network Only Policy SE NTP Policy for Domain Controllers v1.0
IA Computers	Foxboro Win10 Computer Security Compliance Foxboro Server 2022 Member Server Security Compliance Foxboro CCS Computers Foxboro FoxView Environments Foxboro CNI Computer Policy
Remote Desktop Servers	Foxboro CCS Remote Desktop Servers
Non-IA Servers	Foxboro Base Non-CCS SE NTP Policy for Non-IA Computers v1.0
Non-IA Workstations	Foxboro Base Non-CCS SE NTP Policy for Non-IA Computers v1.0
Foxboro	SE Windows Event Forwarding WEF Client v1.0
Thin Clients	SE Windows Event Forwarding WEF Client v1.0

Filtering operations:

Group Policy	Filtering
Default Domain Controllers Policy	Authenticated Users
Default Domain Policy	Authenticated Users
Foxboro Base Non-CCS v1.0	Authenticated Users
Foxboro Base Policy v1.0	Authenticated Users
Foxboro 2022 Domain Controllers Policy v1.0	Authenticated Users
Foxboro Domain Policy v2.0	Authenticated Users
Foxboro Enhanced Interactive Logon Banner ON v1.0	Authenticated Users
Foxboro Enhanced Screen Saver Enabled Filtered v1.0	Enable Screen Saver
Foxboro FoxView Environments	Authenticated Users
Foxboro CCS Computers v2.0	Authenticated Users
Foxboro CCS Remote Desktop Servers v1.0	Authenticated Users
Foxboro CCS Users Filtered v1.0	Enable Screen Saver IA Plant Admins IA Plant Engineers IA Plant Operators IA Plant View Only
Foxboro Interactive Logon Banner OFF v1.0	Authenticated Users
Foxboro Plant Admins Filtered v1.0	IA Plant Admins
Foxboro Plant Engineers Filtered v1.0	IA Plant Engineers
Foxboro Plant Operators Filtered v1.0	IA Plant Operators
Foxboro Plant View Only Filtered v1.0	IA Plant View Only
Foxboro Server 2022 Member Server Security Compliance v1.1	Authenticated Users
Foxboro Win10 Computer Server Security Compliance v1.1	Authenticated Users
Foxboro Thin Client Remote Desktop Access v1.0	Authenticated Users
Foxboro CNI Computer Policy v1.0	Authenticated Users
Foxboro Code Signing Certificates v1.0	Authenticated Users
Foxboro ON Control Network Only Policy v1.0	Authenticated Users
SE NTP Policy for Domain Controllers v1.0	Authenticated Users
SE NTP Policy for Non-IA Computers v1.0	Authenticated Users
SE Bginfo Policy v1.0	Authenticated Users
SE Nozomi Smart Polling Policy v1.0	Authenticated Users
SE Windows Event Forwarding WEF Client v1.0	Authenticated Users

General

12.7 DNS Server Security

The Domain Controllers host DNS Server for name resolution purpose which is one of the major fundamentals of Active Directory. This section gives configuration details for DNS Server security hardening.

12.7.1 Secure Dynamic Updates

The local domain, after automatic creation is ensured that its type set to “Active Directory-Integrated” and “Dynamic updates” is set to “Secure only”.

12.7.2 Restricting Zone Transfers

Zone Transfers for the AD integrated domain is set allowed only between Primary and Secondary Domain Controllers.

12.7.3 DNS Audit and Log Settings

Domain Controller hosting DNS Server has GPO applied to define “Audit directory service access” for Success and Failure events. Maximum size of the Log file is set to 128 MB and old event will be overwritten as needed.

12.7.4 DNS Server Permissions

The following is a list of the user groups and their respective permissions set on the DNS Server

Group or user names	Permissions
Administrators	Allow: Read, Write, Create All Child objects, Special Permissions
SELF	Special Permissions
DnsAdmins	Allow: Full Control, Read, Write, Create All Child objects, Delete Child objects, Special Permissions
Domain Admins	Allow: Full Control, Read, Write, Create All Child objects, Delete Child objects
Enterprise Admins	Allow: Full Control, Read, Write, Create All Child objects, Delete Child objects
Enterprise Domain Controllers	Allow: Full Control, Read, Write, Create All Child objects, Delete Child objects, Special Permissions
Pre-Windows 2000 Compatible Access	Allow: Special Permissions
System	Allow: Full Control, Read, Write, Create All Child objects, Delete Child objects

General

12.7.5 Protection against Name Pollution

The Advanced protection settings on DNS Servers set to "Secure cache against pollution."

12.8 Time Synchronization

D

All non-IA nodes in the Cybersecurity and PIN network will be configured to synchronize the time from the primary/secondary domain controllers using NTP protocol, the domain controllers, will synchronize the time from the NTP server.

NTP server is located in which zone?

12.9 Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
LDAP Plain LDAP is cleartext unless you enable StartTLS or switch to LDAPS.	TCP 389
LDAP UDP	UDP 389
LDAPS	TCP 636
DNS Standard DNS is cleartext	TCP/UDP 53
SMB SMBv3 supports encryption, but older versions (SMBv1/2) do not.	TCP/UDP 445
KERBEROS	TCP/UDP 88
DCE-RPC RPC is not encrypted by default	TCP/UDP 135
LDAP-GC Global Catalog queries are cleartext	TCP 3268
KERBEROS CHANGE PASSWORD	TCP/UDP 464

General

D

12.10 Non-Repudiation:

To ensure that actions taken within the Cybersecurity zone can be attributed to specific human users and cannot be later denied (non-repudiation).

1. **User Identification and Authentication**

- All human users access control systems using unique Active Directory (AD) credentials.
- Domain Controller logs all events as described in 12.5.3.
- Group Policy is enforced to prevent local or shared accounts.

2. **Event Logging and Correlation**

All user activity is logged via:
- Windows Security Event Logs.
- Local application logs (where applicable).
- Forwarding all events and logs to the centralized RMPLOG Syslog server.
- All logs are timestamped and correlate user actions to usernames and machine IPs.

3. **Time Synchronization Integrity**

- All system clocks are synchronized with the PDC/SDC which backed up by an NTP server with a GPS antenna, ensuring consistent timestamps across logs.

4. **Access and Role Mapping**

- Access control follows a defined RACI matrix in Appendix F, mapping Responsible and Accountable roles to their AD group membership.
- Only users have privilege access can access, modify, or Configure systems.

General

13 STANDALONE WINDOWS HARDENING

This section illustrates the hardening for the standalone computers and users using the local group policies.

13.1 Group Policy for Computer Settings

This policy will provide hardening for the computer settings such as:

- Password settings.
  - Password history 12 password remembered.
  - Maximum age 180 days.
  - Minimum age 1 days.
  - Minimum password length 12.
  - Password complexity enabled.
- Account Lockout
  - Account threshold 10 invalid logins.
  - Account lockout duration 15 minutes.
  - Reset account lockout counter after 15 minutes.
- Audit policy.
  - Audit account logon event success, failure.
  - Audit account management success, failure.
  - Audit logon events success, failure.
  - Audit policy change success, failure.
  - Audit system events success, failure.
- Security options
  - Shutdown: allow system to be shut down without having to log on disabled.
  - Interactive logon: do not require CTRL + ALT + DEL disabled.
  - Interactive logon: Message text for users attempting to login: set banner.
  - Interactive logon: Message title for users attempting to login: set title.
- Windows Firewall Disabled.
- Prevent computer power button to shut down the computer.
- Administrative Templates for Computer settings.

13.2 Group Policy for Administrator User Accounts

This policy will provide hardening for Administrator user accounts settings such as:

- Remove Games / Music & other Media features.
- Remove Home Computer Options.
- Remove access to change resolution as this might affect HMI settings.
- Disable Autorun.

13.3 Group Policy for Non-Administrator User Accounts

This policy will provide hardening for non-Administrator user accounts settings such as:

- Remove Games / Music & other Media features.
- Remove Home Computer Options.
- Remove access to change resolution.
- Disable Autorun.
- Remove Access to C & D drives.
- Remove everything from start menu.
- Disable PowerShell.
- Disable CMD.
- Disable Task Manager.
- Disable all control panel options.
- Restrict Desktop.
- Disable windows shortcuts.
- Remove all options from power off except logoff.

14 NTP SERVER

The Time synchronization function for the PDC is achieved by redundant pair of NTP Servers connected to GPS with Antenna. NTP Servers will be connected to PIN Switches.

14.1 NTP Server Security and hardening

The following configurations will be applied for the NTP Servers:

- Configure the IP Address, Name, Location, Contact.
- Default admin and user accounts credential to be changed and Disabled.
- New two Admin accounts will be created (AD account), with superuser access.
- Telnet disabled.
- SSH enabled.
- Unused ports disabled.
- IPv6 to disabled on all interfaces.
- Disable USB ports.
- Shell timeout 10 minutes.
- Web timeout 15 minutes.
- HTTP disabled.
- Front Panel to be locked.
- Configure password policy.
    - Minimum length 12 characters
    - Passwords expire enabled.
    - Passwords expire every 180 days.

General

15 MICROSOFT NPS (RADIUS) SERVER

NPS as RADIUS server is a client-server model architecture. When the user requests to access the network service with the user credentials, then the authentication is requested to NPS server using Access-Request packet. Further it evaluates the connection and forward credentials to the Domain controller for authentication, where the user is authenticate based on policies and NPS server sends Access-Accept Packet to the device.

Microsoft Network policy server is utilized, and it allows to centrally configure and manage user authentication, authorization, and accounting for IEEE802.1x enabled wired network. UDP ports 1812 and 1645 for RADIUS authentication messages and ports 1813 and 1646 for RADIUS accounting messages. By default, these ports are not fully secure unless additional encryption is applied, Ensure secure communication is used

ICSS Firewalls, L3 DCS PIN, cyber and VHN Switches will be integrated with Radius server for user management.

Note: PDC/SDC Server will hold an additional role as NPS (Radius) Server.

15.1 Network Policies

Network policies define the network access permissions granted to authenticated users and devices. These policies can include access controls, such as which resources users can access on the network, and network settings, such as IP address allocation.

NPS policies determine how devices connect and gain network access. There are several different types of policies:

POLICIES	DESCRIPTION
Network Management Authentication Admin	Used for high privilege Administrative Access
Network Management Authentication Read-Only	Used for low privilege Read-Only Access

General

15.2 Radius Client Configuration

A RADIUS client is a RADIUS-enabled device at the network perimeter that enforces access control for users attempting to access network resources.

RADIUS Server – Client Configuration: CLIENT NAME	CLIENT VENDOR	SHARED SECRET
	RADIUS Standard	<*******>
	RADIUS Standard	<*******>
	RADIUS Standard	<*******>
	RADIUS Standard	<*******>
	RADIUS Standard	<*******>

Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
RADIUS authentication traffic	1812
RADIUS accounting traffic	1813

D

16 CERTIFICATE AUTHORITY

Microsoft Active Directory Certificate Services (AD CS) is a crucial component for establishing a secure network infrastructure. It serves as a foundation for Public Key Infrastructure (PKI), issuing and managing digital certificates used for authentication, encryption, and digital signatures. AD CS ensures data confidentiality, integrity, and non-repudiation by binding identities to cryptographic keys, empowering organizations to securely protect sensitive information and resources.
The LDAP (Light Weight Directory Access) protocol enables communication with LDAP servers (AD servers). Various clients, including Microsoft applications, use the LDAP protocol. By default, LDAP communications between client and server applications are not encrypted. One way to help make the LDAP traffic more secure is to tunnel it via SSL/TLS protocols. A default AD installation does not configure LDAP over SSL. Use the information here to configure LDAP over SSL for CCS Enterprise Edition installations.

Following Roles are installed in the Certificate Authority Servers.
- Certification Authority.
- Certification Authority Web enrollment.
- Online Responder.
- Certificate Enrollment Policy Web Service.

16.1 Public Key Infrastructure (PKI) Architecture

The PKI is designed as a two-tier hierarchy to balance security and operational manageability. At the top is an offline Root CA, which is used solely to sign subordinate CA certificates and is kept powered off and physically secured. Beneath it is an online Issuing CA, which is domain-joined and responsible for issuing certificates to users, devices, and services within the control system environment. This separation ensures that the Root CA remains isolated from potential threats, while the Issuing CA can operate within the network to support certificate lifecycle operations.
Active Directory Certificate Services. Configuration parameters.

16.2 Certificate Authority Configuration

The Root CA is configured with a shorter certificate lifetime and publishes CRLs to internal-only distribution points. It is integrated with Active Directory to support identity-based certificate issuance. The CA is hardened by disabling unnecessary roles and services, and its access is restricted to authorized administrators only.

16.3 Certificate Revocation Strategy

Given the air-gapped nature of the environment, Certificate Revocation Lists (CRLs) are the primary mechanism for revocation checking. CRLs are published to an internal HTTP server accessible via internal DNS. Delta CRLs is enabled to reduce the size and frequency of full CRL downloads. The Issuing CA is configured to include CRL Distribution Point (CDP) and Authority Information Access (AIA) extensions in all issued certificates, pointing to internal-only URLs.

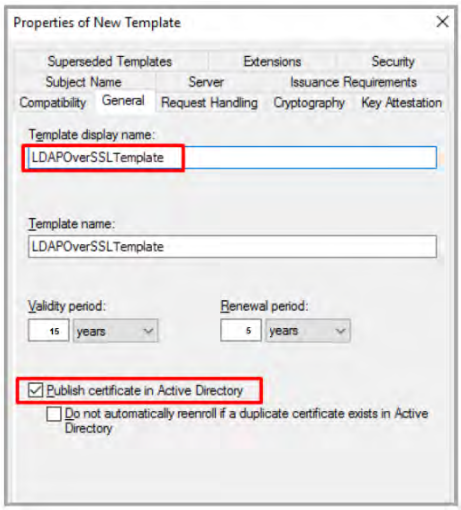
General

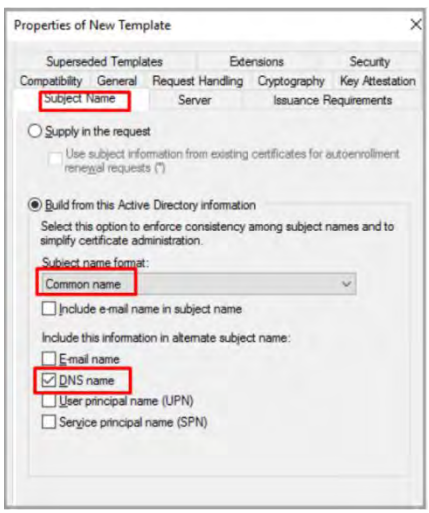
16.4 TPM-Based Key Protection

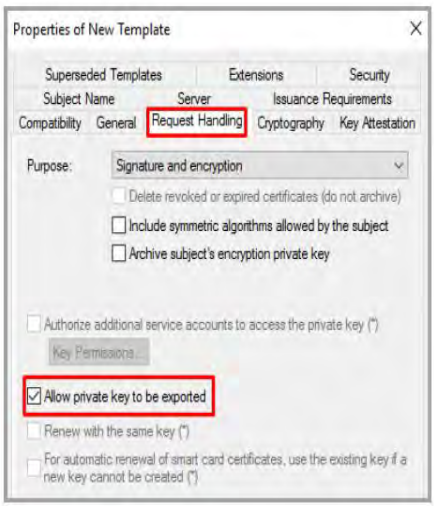
All endpoints in the environment are equipped with Trusted Platform Module (TPM) 2.0. Certificate templates are configured to enforce the use of the Microsoft Platform Crypto Provider, which ensures that private keys are generated and stored within the TPM. Templates are also configured to mark keys as non-exportable, preventing them from being copied or extracted. With this This enabled the private keys remain bound to the hardware and are protected against theft or misuse.

16.5 Certificate Template Design

Templates are created for different identity types, including users, devices, and services. Each template is configured with appropriate key usage and enhanced key usage (EKU) extensions. Subject Name and Subject Alternative Name (SAN) fields are populated based on Active Directory attributes to ensure consistent identity representation. Enrollment permissions are tightly controlled using security groups, and templates are published only to the Issuing CA. Auto-enrollment is enabled for domain-joined devices, while manual enrollment is used for isolated or non-domain systems.







16.6 Identity Mapping and Trust

Certificates are mapped to Active Directory identities using either implicit mapping (based on subject name matching) or explicit mapping (using the userCertificate attribute). This mapping enables authentication and access control decisions to be based on certificate presentation. Group Policy is used to distribute trusted root certificates and enforce certificate-based authentication policies across the environment.

16.7 Certificate Authority Settings

The following settings are applied to the Microsoft Certificate Authority configuration to ensure compliance with the control system's security requirements and TPM integration:

#	Settings	Value
1	CA Type	Enterprise Root
2	Cryptographic Provider	RSA# Microsoft Software Key Storage Provider
3	Hash Algorithm	SHA256
4	Key Length	2048
5	Allow Administrator Interaction	Disabled
6	Certificate Validity Period	25 Years
7	Store Credentials Using TPM-backed Keys	`certutil -csp "Microsoft Platform Crypto Provider" -keyusage CERT_KEY_ENCIPHERMENT_KEY_USAGE`

CAsrvcs service account is used for the Certificate authority Servers.

Certificate Authority Servers certificates are imported to the Trusted Root Certification Authorities store in the Foxboro Domain Policy v1.1 in the ICSS Active Directory.

16.8 Firewall Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
Kerberos	464
LDAP	389
LDAPS	636
HTTPS	443
Global Catalog over SSL	3269 (TCP)
HTTP	80 (TCP)

General

17 CENTRALIZED PATCH MANAGEMENT

Approved MS Patches are available in Schneider Electric Global Customer Support Website. These can be updated locally or through Centralized patch management Server. The Centralized Patch Management Server utilizes Microsoft Windows Server Update Services (WSUS) to manage the distribution of the windows OS security updates released from Schneider Electric GCS through the WSUS server to DCS Servers and workstations in the RMP L3 PIN/CS network. The WSUS allow administrators to manage and distribute updates through the WSUS Administration console. Updates will be imported manually by Administrator once patches are qualified.

17.1 Configurations

RMWSUS Server will host the WSUS server role and services to distribute the Microsoft windows update patches as per the qualification and configurations illustrated in the following sections providing window updates centrally- controlled environment.

The WSUS clients will be set to use the GPO for WSUS group targeting. Qualified updates must be enabled to be downloaded by the security engineers. None of the updates will be downloaded by the client computer until the updates are approved. The list of qualified updates for the IA applications are listed for each operating system type on the Schneider-Electric GCS website as shown below. Once the update has been tested, they are moved to an Approved status on the respective website however, these updates should be tested within the KNPC RMP Plant environment less-sensitive servers prior to approving for production use. The WSUS Server groups will be configured, to provide authorized updates based on Computer Type and Operating System type.

Life Is On | Schneider Electric

Foxboro DCS Approved Microsoft Updates for Windows 10 IoT Enterprise LTSC 2021 and Server 2022

Description

The Microsoft Monthly Rollup includes both security and reliability updates packaged together in a single update. Note that the workstation and server operating systems do not use the same updates.

Response

Prerequisites

Servicing Stack Update (KB) is a pre-requisite ***that must be installed before installation*** of the September Cumulative Update (KB).

- Servicing Stack Update for Windows Server 2022 are included with the monthly rollup
- 2023-10 Servicing Stack Update for Windows 10 Version 21H2 for x64-based Systems (KB5031539)

Microsoft Monthly Rollup

- 2024-09 Cumulative Update for Microsoft server operating system version 21H2 for x64-based Systems (KB5042881)
- 2024-09 Cumulative Update for Windows 10 Version 21H2 for x64-based Systems (KB5043064)

General

17.2 WSUS Authentication

Active Directory authentication will be used for WSUS. There is no application authentication, access to WSUS console is limited to IA Plant Admins, IA Plant Engineers and KNDomainAdmin security groups that will be authorized to have access to the WSUS server.

17.3 Windows Update Criteria

Only Critical Security updates that are tested and qualified by Schneider Electric Foxboro Factory that is released in GCS support website, will be imported, and installed to the RMP systems.

17.4 Computers Windows Update Settings

Group Policy is used to enforce configuration settings for Automatic updates as described earlier in sections.

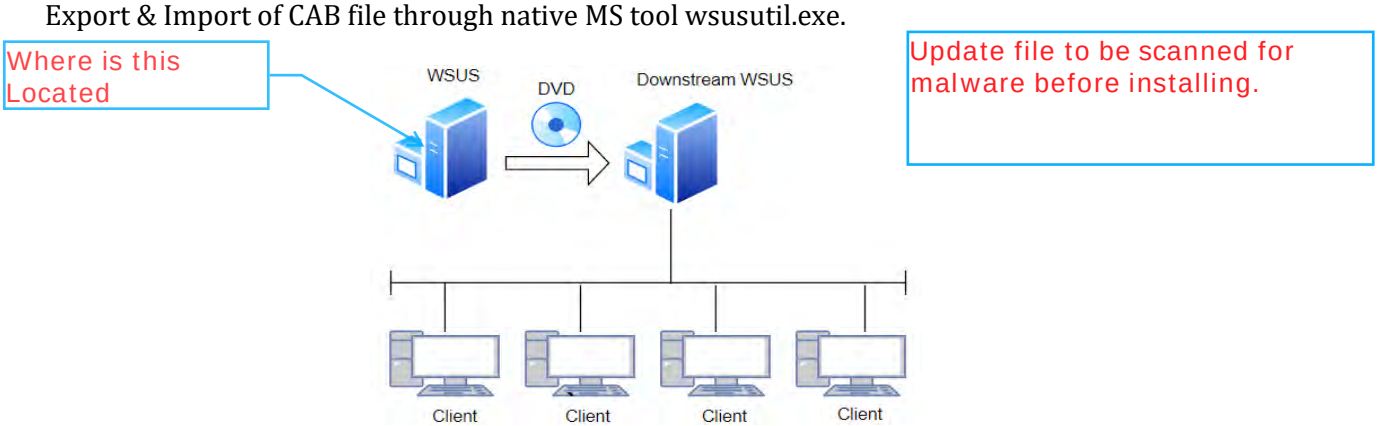
- Port Configuration:

  The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
WSUS HTTPS	TCP 8531

17.5 Importing Offline updates without direct Internet connectivity to WSUS

Manual import of the Microsoft Updates to an Offline WSUS Server a Microsoft digitally signed CAB file and Metadata for the update are required. The qualified MS windows update from GCS will be downloaded to a WSUS connected to the MS update catalog, once CAB files and metadata are downloaded, they will be exported to a DVD and imported to the offline downstream WSUS Server. Export & Import of CAB file through native MS tool wsusutil.exe.



General

18 STANDALONE PATCH MANAGEMENT

Schneider Electric publishes security information updates on the Global Customer Support website. updates relating to the Microsoft windows OS are provided.
During the Staging and Installation phase, Schneider Electric will install the factory qualified patches listed on the GCS website.

Due to the criticality of Safety Systems, patching should be considered. Operating Systems must be up to date with the latest Schneider Electric Critical and Important Security Patches.

Qualified patches can be copied to portable removable media and followed by Anti-virus scan.

General

19 CENTRALIZED ENDPOINT PROTECTION

Schneider Electric incorporates globally recognized third-party security packages that provide additional security enhancement features to complement the security features already built into our products. These security suites are referred to as Trellix Endpoint Protection.

- Trellix Endpoint Security (ENS) 10.7.0
- Trellix Agent 5.7.9
- Device Control (DLP) 11.10.0
- Trellix Application and Change Control (TACC, formerly known as Solidcore)
- 8.3.4
- ePolicy Orchestrator (ePO) 5.10 Service Pack 1
- Rogue System Detection (RSD) 5.0.6

Trellix EPP Products can be installed in one of two configurations:
- Self-Managed
- Managed solution (ePO Managed)

Self-Managed

- In self-managed mode, Endpoint Security (ENS) software is installed and managed on each individual system manually without a centralized management system. Operational parameters of modules and features can be specified during installation. The Trellix self-managed solution requires that you install Trellix ENS on every endpoint manually. You need to update the DAT files and Exploit Prevention content on every computer manually as well.

ePO Managed

- The managed solution allows you to install and monitor the Trellix products on your endpoints from a single, centralized location using the ePO console. It also allows you to update the DAT files, Exploit Prevention content, and patches on the endpoints from the ePO console. In the Managed mode Endpoint Security, Rogue System Detection, Device Control, and Solidcore (Trellix Application and Change Control (TACC)) are supported. Using the Trellix managed solution, you can manage the security products from the ePO console and assign, control, and monitor the clients.

General

19.1 End Point Security (ENS)

ENS is the only supported Trellix product that can be installed without ePO in a Self-managed mode. The other applications such as RSD, Device Control, and Solidcore (Trellix Application and Change Control (TACC)) require ePO.

Endpoint Security consists of these modules:

- Threat Prevention
- Trellix Agent (installed with ENS)

Threat Prevention

- Threat Prevention replaces the traditional antivirus protection and intrusion prevention. It improves performance and productivity by bypassing scanning of the trusted processes. It prioritizes suspicious processes and applications. It also provides adaptive behavioral scanning to monitor and report on suspicious activity during the on-demand scan CPU utilization is set to low to protect resource of the asset. Keeping this solution patched and up to date with the latest qualified version is crucial to the security of a system. In addition to these types of changes, Trellix provides product patches to incorporate fixes for installed security applications.

Exploit Prevention Content

- An exploit is a sequence of commands that allows an attacker to take advantage of a vulnerability or a bug in a process or software application. To control a system, the attacker needs to take advantage of a chain of vulnerabilities in the system. Blocking any attempt to exploit a vulnerability in the chain results in blocking the entire exploitation attempt.

- The Threat Prevention module in Trellix ENS provides a content-based Exploit Prevention update every month.

19.2 ePolicy Orchestrator

Trellix ePolicy Orchestrator provides the ability to centrally manage these Trellix components: Agent, RSD, DLP, Solidcore (Trellix Application and Change Control (TACC)), and ENS. It allows users to install, configure, update, monitor, and deploy these applications to the client workstations and servers in the Foxboro DCS Active Directory domain on the control network.
ePO can be used to keep the virus signature (DAT) files up to date from a single location, which helps avoid updating DAT files and performing other tasks manually on each machine in the system. Another major benefit of ePO is the ability to monitor the other Trellix security packages from the ePO console.

General

ePO Dashboards show the status of the products and stations that ePO is managing. A set of predefined dashboards is provided with the ePO software. ePO 5.10 server has been qualified for use on Microsoft Windows Server 2022 with CCS software v9.8 or later.

In this Project, ePO managed solution will be used for all DCS Servers and workstations.

19.2.1 ePO Authentication

ePO server supports both internal and Active Directory authentication. Active Directory will be the primary authentication mechanism. The internal authentication will be configured for two accounts, the admin and epoadmin account. The admin account will be used for the initial configuration, and then be used for break glass support (when Active Directory authentication malfunctions).

The default administrator accounts 'admin' and 'epoadmin' will be renamed and a complex password will be configured. The Schneider Electric CS Engineer account will be mapped to ePO administrators' roles.

No other account will be provided access to ePO.

The ePO application requires a three-service account, a read only domain account for the synchronization of the active directory domain, ePO services account and a Microsoft SQL Server service account.

Account	Authentication Mechanism	Role
admin	ePO local	Initial configuration
epoadmin	ePO local	Disabled
srvADRead	Active Directory	Read active directory account – domain account
srvEPO	Active Directory	ePO service account

19.2.2 ePO synchronization with the Active Directory servers

The computers in the ePO management interface are organized using a method of Automatic synchronization with Domain Controller Active Directory. The ePO Server is Synchronized with the ICSS, SCADA Active Directory structure, by importing systems and the Active Directory sub-containers (as System Tree groups) and keeping them up to date with Active Directory. During each time the synchronization happens, both systems and the structure are updated in the System Tree to reflect the systems and structure of Active Directory. The hierarchical structure from AD is replicated to the ePO System Tree that allows organizing systems in the environment network into groups and subgroups. The default System Tree structure includes one group that cannot be modified or deleted.

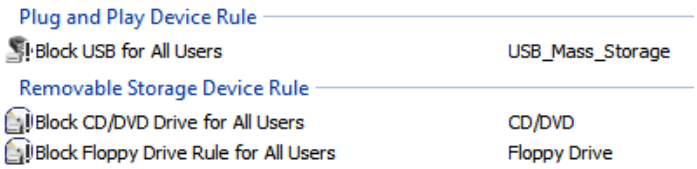
General

19.3 Trellix agent

The Trellix Agent is the client-side component that helps provide secure communication between the ePO and managed products. It serves as an updater for the Trellix products. The Trellix Agent runs in the background, gathers information and events from the managed systems, and sends them to the ePO server. It installs products and their updates including DAT files and Exploit Prevention content. It enforces policies and tasks on the managed systems and sends events back to the ePO server.

19.4 Device Control (DLP)

Device Control is a portion of Trellix's Data Loss Prevention (DLP) software that helps to reduce the risk of an unintentional disclosure of confidential information. It helps prevent unauthorized use of removable media devices (such as CD\DVD, USB, and Floppy disk) to guard against data leaks. It enables to specify and categorize which devices may or may not be used and enforce which users can or cannot transfer files using these devices.
DLP rules access to the following devices is blocked for non-privileged users.



Access to CD/DVD and/or USB shall be granted through the DLP override key generated from the Help Desk page in the ePO Console.

19.5 Trellix Application Change and Control (TACC) Solidcore

Trellix Application Control uses an application called Solidcore that helps block unauthorized applications and changes to the process control networks by combining the creation of an Allowlist and change control technology.

Application Control functions by listing the processes that are allowed to run on fixed function devices. It helps block vulnerable, unauthorized, or malicious applications that can compromise the integrity of systems. Creating an Allowlist helps secure the system and only allows authorized updates or changes that are defined by the administrators or trusted sources.

Application Control operates in four modes: Disabled mode, Enabled mode, Observe mode, and Update mode. Application control can change from one mode to another mode.

The IAInstaller, KNDomainAdmin and OTSecurity groups are added as trusted users to ensure that CCS application and updates to CCS are appropriately authorized, in addition, the Foxboro, Invensys and third-party certificates used in applications are added as trusted publishers. By configuring the

General

trusted users and the trusted publishers the operation of CCS is not interfered with and unauthorized changes are prevented.

Terms	Definition
Authorizing files and programs	Typically, the applications and executable files remain unchanged over prolonged periods of time. However, if needed, you can allow certain applications and executable files to create, modify, or delete files in the Allowlist. To design a trust model and allow additional users or programs to help modify an endpoint, you can use one of these methods.
Disabled Mode	In disabled mode the application control is installed but not running on the system. You can change from Disabled mode to Update mode or Enabled mode. When switching between the modes, restarting of the machine may be required.
Enabled Mode	In Enabled mode, you can only run the applications and files on the Allowlist. You cannot execute the unauthorized software. You can change from Enabled mode to Disabled or Update mode. When switching between the modes, restarting of the machine may be required.
Exclusions	Exclusions are the list of paths and applications/files that will not be scanned. They help enable you to minimize false positive notifications, minimize needless data flow and help ensure that alerts are legitimate security threats.
Installer	Refers to an application installer identified by its checksum (SHA1) that is allowed to install or update software. When a program (or an installer) is configured as an authorized installer, it gets both the attributes - authorized binary and updater. Regardless of whether the installer was originally present on the endpoint or not, it is allowed to execute and update software on the endpoint.
Observe Mode	In Observe mode, the application is running but does not stop any changes to be made to the endpoints. Instead, events are logged for cases where an application would have been blocked in Enabled mode. When switching between the modes, restarting of the machine may be required.

General

Terms	Definition
Publisher	Refers to a publisher or trusted certificate (associated with a software package) that is permitted to run on an endpoint. After you add a certificate as a publisher, you can run the publisher software that is signed by the certificate. For example, if you add Adobe's code signing certificate as a publisher, the software issued by Adobe and signed by Adobe's certificate will be permitted to run.
Trusted Directory	Refers to a directory (local or network share) identified by its Universal Naming Convention (UNC) path. After you add a directory as a trusted directory, endpoints are permitted to run any software present on that directory.
Trusted User	Refers to an authorized Windows user with privileges to dynamically add to the Allowlist. For example, add the administrator as a trusted user to allow the administrator to install or update any software. While adding the user details, you also need to provide the domain details.
Updater	Refers to an application permitted to update the endpoint. If a program is configured as an updater it is allowed to install new software and update existing software. For example, if you configure Adobe 8.0 updater program as an updater, it can periodically patch the necessary files.
Update Mode	Refers to a time-window during which the changes are allowed on an endpoint. Place the endpoints in Update mode to perform ad-hoc changes to the endpoints. When switching between the modes, restarting of the machine may be required.

19.6 Trellix Updates

Trellix components are updated periodically by Trellix. Schneider Electric qualified components and engine updates are listed on the Global Support site (GCS).

A dedicated Task will be created to enable periodic updates for managed stations to request updates from ePO server on regular basis. A task schedule will be created to run the task on weekly basis.

To manually import Trellix DAT and EPContent update to the Trellix ePO server.
Copy the update files downloaded from Schneider Electric GCS to the Trellix ePO server.

General

19.7 Schneider Electric Supplied Policies

Schneider Electric supplies default policies for the managed and self-managed solutions.

- Trellix Agent (MA)
  - Policies_For_Trellix_Agent.xml
- Endpoint Security (ENS)
  - Policies_For_Endpoint_Security_Common.xml
  - Policies_For_Endpoint_Security_Threat_Prevention.xml
- Trellix Application Change and Control (TACC) Solidcore
  - Policies_For_Solidcore_8.3.4xml
  - Solidcore_RuleGroups.xml

Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
Agent-server communication Secure port (HTTPS)	443
Agent wake-up communication port	8081
Agent broadcast communication port	8082
Console to application server communication port (HTTPS)	8443
Client to server authenticated communication port	8444

19.8 Scan Schedule

Refer to Appendix-A for the table containing the scanning schedule for the endpoints.

General

20 STANDALONE TRELLIX ENDPOINT PROTECTION

Schneider Electric incorporates globally recognized third-party security packages that provide additional security enhancement features to complement the security features already built into our products. Contemporary security applications go beyond traditional firewall and antivirus software to provide advanced host intrusion prevention, application control (TACC). These security suites are referred to as Endpoint Protection (EPP).

Trellix Endpoint Security self-managed installed on safety workstations combines anti-virus and Threat Prevention technologies to stop and remove malicious files.

20.1 Endpoint Security (ENS)

Endpoint Security consists of these modules:

- Threat Prevention.
- Trellix Agent (installed with ENS).

20.2 Threat Prevention

Threat Prevention replaces the traditional antivirus protection and intrusion prevention. It improves performance and productivity by bypassing scanning of the trusted processes. It prioritizes suspicious processes and applications. It also provides adaptive behavioral scanning to monitor and report on suspicious activity. Keeping this solution patched and up to date with the latest qualified version is crucial to the security of a system. In addition to these types of changes, Trellix provides product patches to incorporate fixes for installed security applications.

20.3 Exploit Prevention Content

An exploit is a sequence of commands that allows an attacker to take advantage of a vulnerability or a bug in a process or software application. To control a system, the attacker needs to take advantage of a chain of vulnerabilities in the system. Blocking any attempt to exploit a vulnerability in the chain results in blocking the entire exploitation attempt.

The Threat Prevention module in Trellix ENS provides a content-based Exploit Prevention update every month.

20.4 Trellix Application Change and Control (TACC) Solidcore

Trellix Solidcore consists of Application Control. It uses an application called Solidcore that helps block unauthorized applications and changes to the process control networks by combining the creation of an Allowlist and change control technology.
Application Control functions by listing the processes that are allowed to run on fixed function devices. It helps block vulnerable, unauthorized, or malicious applications that can compromise the integrity of systems. Creating an Allowlist helps secure the system and only allows authorized updates or changes that are defined by the administrators or trusted sources.

Terms	Definition
Authorizing files and programs	Typically, the applications and executable files remain unchanged over prolonged periods of time. However, if needed, you can allow certain applications and executable files to create, modify, or delete files in the Allowlist. To design a trust model and allow additional users or programs to help modify an endpoint, you can use one of these methods.
Disabled Mode	In disabled mode the application control is installed but not running on the system. You can change from Disabled mode to Update mode or Enabled mode. When switching between the modes, restarting of the machine may be required.
Enabled Mode	In Enabled mode, you can only run the applications and files on the Allowlist. You cannot execute the unauthorized software. You can change from Enabled mode to Disabled or Update mode. When switching between the modes, restarting of the machine may be required.
Exclusions	Exclusions are the list of paths and applications/files that will not be scanned. They help enable you to minimize false positive notifications, minimize needless data flow and help ensure that alerts are legitimate security threats.
Installer	Refers to an application installer identified by its checksum (SHA1) that is allowed to install or update software. When a program (or an installer) is configured as an authorized installer, it gets both the attributes - authorized binary and updater. Regardless of whether the installer was originally present on the endpoint or not, it is allowed to execute and update software on the endpoint.
Observe Mode	In Observe mode, the application is running but does not stop any changes to be made to the endpoints. Instead, events are logged for cases where an application would have been blocked in Enabled mode. When switching between the modes, restarting of the machine may be required.
Publisher	Refers to a publisher or trusted certificate (associated with a software package) that is permitted to run on an endpoint. After you add a certificate as a publisher, you can run the publisher software that is signed by the certificate. For example, if you add Adobe's code signing certificate as a publisher, the software issued by Adobe and signed by Adobe's certificate will be permitted to run.

General

Terms	Definition
Trusted Directory	Refers to a directory (local or network share) identified by its Universal Naming Convention (UNC) path. After you add a directory as a trusted directory, endpoints are permitted to run any software present on that directory.
Trusted User	Refers to an authorized Windows user with privileges to dynamically add to the Allowlist. For example, add the administrator as a trusted user to allow the administrator to install or update any software. While adding the user details, you also need to provide the domain details.
Updater	Refers to an application permitted to update the endpoint. If a program is configured as an updater it is allowed to install new software and update existing software. For example, if you configure Adobe 8.0 updater program as an updater, it can periodically patch the necessary files.
Update Mode	Refers to a time-window during which the changes are allowed on an endpoint. Place the endpoints in Update mode to perform ad-hoc changes to the endpoints. When switching between the modes, restarting of the machine may be required.

20.5 Trellix Updates

Schneider Electric publishes security information updates on the Global Customer Support site. Updates relating to Product, Microsoft and Trellix updates are provided.
Trellix components are updated periodically by Trellix. Schneider Electric qualified components and engine updates are listed on the Global Support site (GCS).

To manually import Trellix DAT and EPContent update to the workstation copy the update files downloaded from Schneider Electric GCS to the workstations using portable removable media and run the update files manually then run the update now in the ENS Console.

20.6 Schneider Electric Supplied Policies

Schneider Electric supplies default qualified policies for the managed solutions as follow:

- Trellix Agent (MA)
  - Policies_For_Trellix_Agent.xml
- Endpoint Security (ENS)
  - Policies_For_Endpoint_Security_Common.xml
  - Policies_For_Endpoint_Security_Threat_Prevention.xml
- Trellix Application Change and Control (TACC) Solidcore Policies
  - Policies_For_Solidcore_x.x.xml
  - Solidcore_RuleGroups.xml

21 CENTRALIZED BACKUP AND RECOVERY

Schneider Electric qualified Veritas System Recovery for Backup and Recovery. Veritas System Recovery 23 software is supplied as part of this project for DCS Servers/Workstations, and Cybersecurity Servers. The VSR is installed locally to all the endpoints, and it will back up the machines HDDs locally to Z Drive, to minimize the downtime and avoid disasters by recovering the complete systems. After local backup is completed, VSR will push a copy to the centralized backup server as mentioned in the below sections.
The Veritas System Recovery will be configured to maintain two set of complete backups for Server or workstation.

The backup files will be stored locally on the dedicated backup partition (Z:\) with capacity of 100 GB.

21.1 Backup Authentication

Active Directory authentication will be used to provide authentication for Veritas System Recovery software. The IA Plant Admin, IA Plant Engineer and the KNDomainAdmin security groups will have the privilege to access the Backup server using their given credentials.
No other account will have access privilege to the backup server.

A service account will be created in the active directory to be used by the Veritas System Recovery to authenticate with the backup server to push the offline backup.

21.2 VSR Backup Mechanism

Shall align with KNPC backup retention Policy

- C:\ and D:\ Drives are selected for to be included in the Backup process.
- Backup destination set to Z:\Full Backup.
- Recovery Point set are selected for the Recovery point type.
- Veritas System Recovery will be configured to minimizing the CPU usage using performance throttled to slow to ensure no intervention with normal system operation.
- A backup task is scheduled for each system to run monthly based on the Backup schedule defined.
- The backup application is configured to keep the latest two monthly recovery points on the local system while the older backup copies are purged.
- The automatic update feature is disabled.
- All notifications & pop-ups to user screen are disabled except for the system tray icon.
- The integrity of the backup file is verified after each successful backup.
- Backup encryption for all supplied systems using AES-192 bit.

Backup Integrity Verification details to be included

General

21.3 Offsite Replication

Upon successful completion of the local backup, VSR then push the backed up image to the offsite location defined in the backup plan using SMBv3.

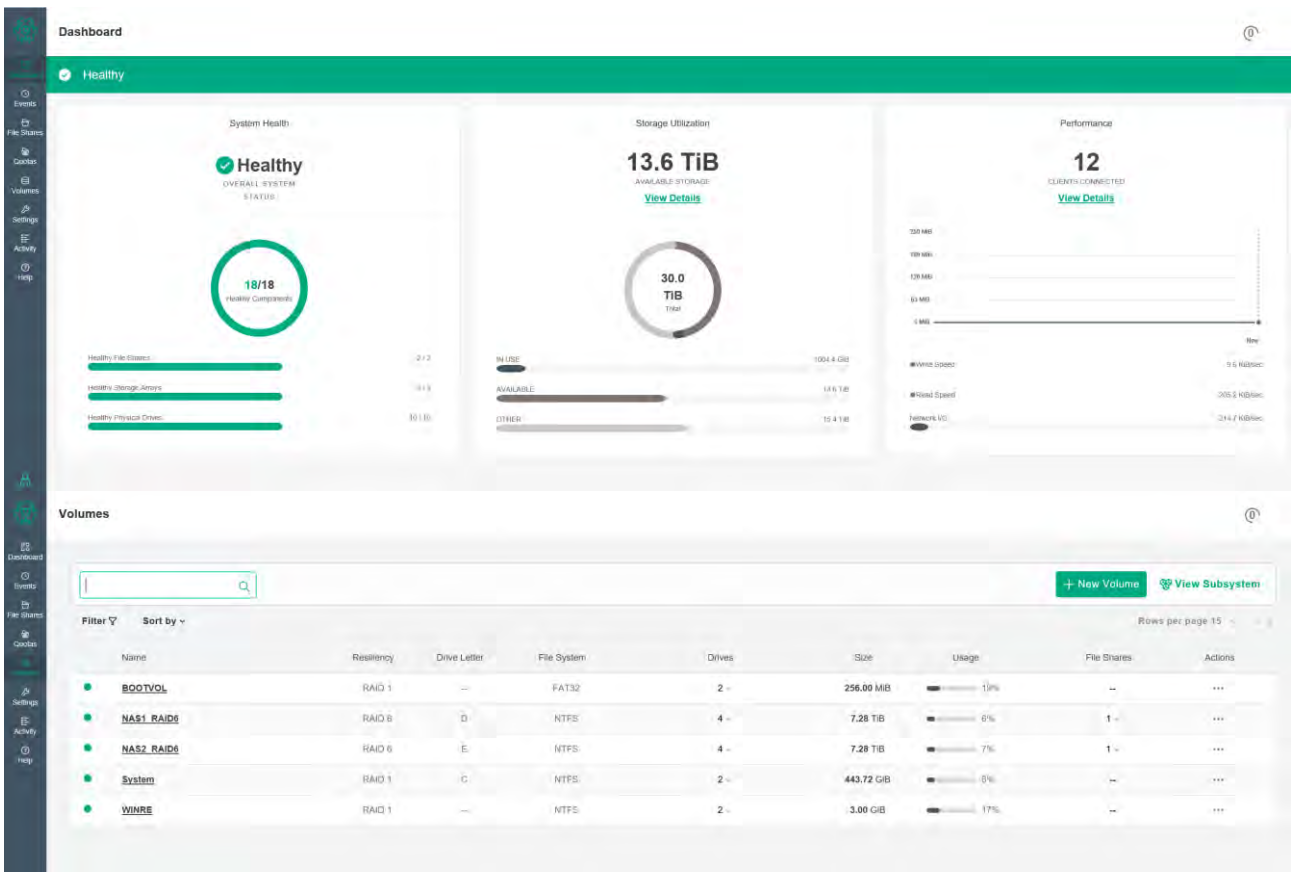
21.4 Backup Schedule

Refer to Appendix-B for the table containing the backup schedule for the endpoints.

21.5 Centralized Backup Server

Network Attached Storage appliance provides a storage that is connected to the L3.2 CS network to allow storage and retrieval of data from the RMP domain infrastructure by authorized service account.

HP Backup server is the appliance that is serving the purpose of Centralized Backup Server.



22 STANDALONE BACKUP AND RECOVERY

Schneider Electric qualified Veritas System Recovery for Backup and Recovery. Veritas System Recovery 23 software is supplied as part of this project for Schneider SIS/FGS Workstations. The VSR is installed locally to all the endpoints, and it will back up the machines HDDs locally to Z Drive, to minimize the downtime and avoid disasters by recovering the complete systems.

The Veritas System Recovery will be configured to maintain two set of complete backups locally.

The backup files will be stored locally on the dedicated backup partition (Z:\) with capacity of 100 GB.

22.1 VSR Backup Mechanism

- C:\ and D:\ Drives are selected for to be included in the Backup process.
- Backup destination set to Z:\Full Backup.
- Recovery Point set are selected for the Recovery point type.
- Veritas System Recovery will be configured to minimizing the CPU usage using performance throttled to slow to ensure no intervention with normal system operation.
- A backup task is scheduled for each system to run monthly based on the Backup schedule defined.
- The backup application is configured to keep the latest two monthly recovery points on the local system while the older backup copies are purged.
- The automatic update feature is disabled.
- All notifications & pop-ups to user screen are disabled except for the system tray icon.
- The integrity of the backup file is verified after each successful backup.
- Backup encryption for all supplied systems using AES-192 bit.

22.2 Backup Schedule

Refer to Appendix-B for the table containing the backup schedule for the endpoints.

23 LOG MANAGEMENT

KIWI Syslog NG will be installed in the Log management server VM in Cybersecurity server RMCSV1. All logs will be accessible from KIWI Dashboard as the log management server. Access to Central Log Server based on RACI matrix available in appendix F

Cybersecurity zone 3.2 log sources's shall also include

23.1 Log sources.

- Windows OS machines (in L3 PIN network).
- Network switches (in L3 PIN network).
- ICSS Network firewalls.

KNPC SHALL REVIEW

Note:

1. L2 network switches, and SIS/FGS assets will not forward logs to the Central Logging Server.
2. L2 MESH Control network messages are logged to DCS syslog server (RMPXIQ).

23.2 Events Collecting.

Not limited to following event collection. The system shall capable to add the event as per project requirements

- Windows Event logging.
- Network equipment logging.
- Firewalls event logging.
- Successful and failed logins attempt to systems.
- Files and Networks Accessed.
- Use of system utilities.
- De-activation of ENS.

UDP 514 is not encrypted by default, logs can be intercepted.

23.3 Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
Kiwi syslog service	UDP 514
Kiwi syslog service	TCP/UDP 162

Also unencrypted by default unless SNMPv3 is used.

23.4 Log Forwarding.

All logs will be forwarded to the KNPC IT Security Information and Event Management (SIEM) using a KNPC-provided log collector/forwarder at L3.5.

General

D

23.5 Events Timestamp

The Time field will be displayed in the Kiwi Syslog Server NG event page represents the timestamp of when a log message is received by the Kiwi Syslog Server. While the kiwi syslog server time is synchronized from the PDC and SDC servers.

D

23.6 Logs override

Clean up schedule is configured to override log file in the log data store location server with following settings.

- Task Name: Clean-up
- Schedule:
    - Minutes: Every Minute.
    - Hours: Every Hour.
    - Day: Ever 7 Days Starting on Sunday.
    - Month: Every Month.
    - Year: Every Year.
- Source:
    - Source Location: D:\KiwiSyslog_Log_Store_Database\
    - Source Files: File mas *.*
    - File Size: any
    - File Age: At least 7 Days.
- Options
    - Clean-up options : Remove empty folders.

General

24 NETWORK PERFORMANCE MONITORING (NPM)

The Cybersecurity architecture employs centralized monitoring, alerting and reporting mechanism based on the WhatsUp Gold Network Performance Monitor (NPM).

All RMP L3 PIN/CS networks, ICSS firewalls will report to the NPM server for performance and availability monitoring. They will report to RMPNPM. WhatsUp Gold web console could be accessed through the Cybersecurity management client or through the NPM server directly.

KNPC Shall review

Note:

1. L2 MESH Control network, and SIS/FGS assets will not be monitored by the NPM.
2. It's not recommended to Utilize L2 MESH Control, Network with non-critical Cyber traffic for monitoring through NMS. L2 MESH Control network will be monitored by DCS syslog server (RMPXIQ).

24.1 NPM Monitoring Protocols

The following is the list of protocols used by WhatsUp Gold Orion to gather statistics and configuration data:

- ICMP: is used on DCS Servers, Workstations, ICSS firewalls, and CS/PIN Switches to provide availability information.
- SNMPv2c: is used on DCS Servers, Workstations to collect performance statistics.
- SNMPv3: is used on L3.2 firewalls, and CS/PIN Switches to collect performance statistics.

24.2 NPM monitoring details.

NPM will be configured to monitor the following details based on the machine type.

- Windows operating systems machines:
  - Machine availability.
  - C, D, Z Drive utilization.
  - RAM utilization.
  - CPU utilization.
  - Network ports utilization and availability.
  - Redundant power supply status.
  - Fan Utilization.
- CS and PIN Network Switches:
  - RAM utilization.
  - CPU utilization.
  - Network ports utilization and availability.
- ICSS Firewalls:
  - RAM utilization.
  - CPU utilization.
  - Network ports utilization and availability.

General

24.3 NPM Authentication

Active Directory authentication will be used to provide authentication to the NPM Server. The IA Plant Admin, IA Plant Engineer and the KNDomainAdmin security groups will have the privilege to access the NPM server using their given credentials.

No other account will have access privilege to the NPM server.

Port Configuration:

The following tables display the ports needed for communication through a firewall.

SERVICE NAME	PORTS
SNMP Trap Passive Monitoring	UDP/162
Monitoring of Simple Network Management Protocol (SNMP) data	UDP/161
IMCP Echo requests to devices (Ping)	ICMP

D

24.4 NPM Alert Center

This section outlines the design for implementing alert notifications using WhatsUp Gold to monitor critical infrastructure resources such as servers, workstations and network devices.

24.4.1 Alert Triggers

Alerts will be based on the following event types:

- Availability: Device or service is unreachable or not responding.
- Performance: Metrics exceed defined thresholds (e.g., CPU > 85%, Disk > 90%).

24.4.2 Monitoring Types

Monitor Type	Description
Active Monitors	Direct status checks (Ping, HTTP, Port, etc.)
Performance Monitors	Threshold-based checks on resource metrics

General

24.4.3 Alert Threshold Configuration

Thresholds for performance alerts will follow baseline utilization and availability average patterns, conditions are configurable.

Default values include:

Threshold Name	Condition	Duration
CPU utilization	> 90%	more than 50 minutes
Memory usage	> 95%	more than 1 hours
Disk space utilization	> 95%	more than 4 hours
Interface Utilization	> 90%	more than 60 minutes
Ping availability	< 95%	more than 30 minutes
Ping response	> 50ms	more than 30 minutes

D

24.5 NPM Asset Inventory

WhatsUp Gold comes with the capability to create a complete asset inventory. This asset inventory will use SNMP, IP addressing, and ICMP to automatically discover, locate, and collect comprehensive device information across servers, workstations, switches, and firewalls.

The asset information collected includes

- Asset Tag.
- Asset IP.
- Manufacturer/model.
- ID.
- Serial number.
- Hardware/software and firmware versions.
- Chassis id.
- Module inventory.
- Information about device hardware such as power supplies and fans.

D

25 Appendix-A "EPO – Scan Schedule"

#	System	Location	Machine Tag	Category	Centrally Managed / Self-Managed	Day of the week	Scheduled Time
1							
2							

* The above table will be completed in the detailed design stage.

General

D

26 Appendix-B "VSR – Backup Schedule"

#	System	Location	Tag	Backup Drives	TIER-1 Destination	TIER-1		TiER-2 Destination	TIER-2	
						Day of Month	Scheduled Time		Day of Month	Scheduled Time *
1										
2										

* The above table will be completed in the detailed design stage.

General

27 Appendix-C System Under Consideration

D

28 Appendix-D IEC 62443 SL Table of Compliance

General

29 Appendix-E List of DCS Third Party Interfaces In RMP DCS System

General

D

30 Appendix-F Role Based Access Control (RBAC)

General

D

31 Appendix-G Trellix ENS Schneider Supplied Policies Settings

Policy Settings for the Trellix Agent General

Tab/Area	Field	Value
General Tab		
General Options	Policy enforcement interval (in minutes)	60
	Show the Trellix system tray icon (Windows only)	Selected
	Allow end users to update security from the Trellix system tray menu	Cleared
	Enable Trellix system tray icon in a remote desktop session	Cleared
	Enable agent wake-up call support	Selected
	Enable super agent wake-up call support	Selected
	Accept connections only from the ePO server	Selected
	Run agent processes at lower CPU priority (Windows only)	Selected
	Enable self-protection (Windows only)	Selected
	Enable msgbus authentication using test certificates	Cleared
Reboot options after product deployment (Windows only)	Prompt user when a reboot is required	Selected
	Force automatic reboot after (seconds): 60	Cleared
Agent-server communication	Enable agent-to-server communication	Selected
	Agent-to-server communication interval (minutes):	60
	Initiate agent-to-server communication within 10 minutes after startup if policies are older than (days)	1

General

Tab/Area	Field	Value
	Retrieve all system and product properties (recommended). If unchecked retrieve only a subset of properties.	Selected
SuperAgent Tab		
Repository Options	Convert agents to SuperAgents	Cleared
Relay Options	Enable Relay Communication	Cleared
RelayServer Options	Enable Relay Server	Cleared
Events Tab		
Priority event forwarding:	Enable priority event forwarding	Selected
	Forward events with a priority equal or greater than	Major
	Interval between uploads (minutes)	5
	Maximum number of events per upload	10
Logging Tab		
Application logging	Enable application logging	Selected
	Enable detailed logging	Selected
	Log file size (MB)	10
	Roll over count	10
Remote logging	Enable remote logging	Selected
	Limit in lines	200
	Enable remote access to log	Selected
Updates	Product update log file	Blank
	Post-update options	Blank
	DAT file downgrades	Cleared
	Update type and repository branch to use	Current
Peer-to-Peer Options	Enable Peer-to-Peer Communication	Cleared
	Enable Peer-to-Peer Serving	Cleared
Deployment	Incompatibility check	Selected

General

Product Improvement Program

Tab/Area	Field	Value
Options	Disabled	Cleared

Repository

Tab/Area	Field	Value
Repositories		
Repository list selection:	Use this repository list	Selected
Select repository by:	Use order in repository list	Selected
Repository list:	Automatically allow clients to access newly- added repositories	Selected
Name: 02AVS1	Type: Global	State: Enabled
Name: TrellixHttp	Type: Fallback	State: Disabled
		Action: Disable
Proxy		
Proxy Settings	Do not use a proxy	Selected

Troubleshooting

Tab/Area	Field	Value
General		
Language options	Select language used by agent	English

Policy Settings for Endpoint Security
Common: Options

Tab/Area	Field	Value
Show Advanced		
Client Interface Mode	Lock Client Interface	Selected
	Enable client interface lockout	Cleared
Uninstallation	Require password to uninstall client	Selected
Time-Based Administrator Password	NA	
Client Interface Language	English	
Self-Protection	Enable Self Protection	Selected
	Files and folders	Selected
	Action	Block and report
	Registry	Selected
	Action	Block and report
	Process	Selected
	Action	Block and report
	Exclude these Processes	NA
Certificates	None	
Client Logging	Log files location	<SYSTEM ROOT>\% DEFLOGDIR%
	Activity Logging	

General

Tab/Area	Field	Value
	Enable activity logging	Selected
	Limit size (MB) of each of the activity log files	Selected 10
	Activity logging language	Automatic
	Debug Logging	
	Enable for Threat Prevention	Cleared
	Enable for Firewall	Cleared
	Enable for Web Control	Cleared
	Enable for Adaptive Threat Protection	Cleared
	Enable for Threat Intelligence	Cleared
	Limit size (MB) of each of the debug log files	50
	Event Logging	
	Send events to Trellix ePO	Selected
	Log events to Windows Event Log:	Selected
	Threat Prevention events to log	
	Access Protection	Critical and Alert
	Exploit Prevention	Critical and Alert
	On-Access Scan	Critical and Alert
	On-Demand Scan	Critical and Alert
	Firewall events to log	Critical and Alert
	Web Control events to log	Critical and Alert
	Adaptive Threat Intelligence events to log	Critical and Alert
Proxy Server for Trellix GTI	No proxy server	Selected
Default Client Update	Enable the Update Now button	Selected
	Enable Default Client Update task schedule	Cleared
	What to update	Security content, hot fixes, and patches
Managed Tasks	Display managed custom tasks	Selected

Threat Prevention Access Protection

Tab/Area		Field	Value
Show Advanced			
Access Protection		Enable Access Protection	Selected
Exclusions		Exclusion List	
Rules			
Block	Report	Rule	Origin
Cleared	Cleared	Browsers launching files from the Downloaded Program Files folder	Trellix-defined
Cleared	Cleared	Changing any file extension registrations	

General

Tab/Area		Field	Value
Cleared	Cleared	Changing user rights policies	
Cleared	Cleared	Creating new executable files in the Program Files folder	Trellix-defined
Cleared	Cleared	Creating new executable files in the Windows folder	Trellix-defined
Cleared	Cleared	Disabling Registry Editor and Task Manager	Trellix-defined
Selected	Selected	Doppelganging attacks on processes	
Selected	Selected	Executing Mimikatz malware	
Cleared	Cleared	Executing scripts by Windows script host (Cscript.exe or Wscript.exe) from common user folders	Trellix-defined
Selected	Selected	Executing Windows Subsystem for Linux	
Cleared	Cleared	Hijacking .EXE and other executable extensions	Trellix-defined
Cleared	Cleared	Installing Browser Helper Objects or Shell Extensions	Trellix-defined
Cleared	Cleared	Installing new CLSIDs, APPIDs, and TYPELIBs	Trellix-defined
Cleared	Cleared	Modifying core Windows Processes	Trellix-defined
Cleared	Cleared	Modifying Internet Explorer settings	Trellix-defined
Cleared	Cleared	Modifying network settings	Trellix-defined
Cleared	Cleared	Registering of programs to autorun	Trellix-defined
Cleared	Cleared	Remotely accessing local files or folders	Trellix-defined
Selected	Selected	Remotely creating autorun files	Trellix-defined
Cleared	Cleared	Remotely creating or modifying files or folders	Trellix-defined
Cleared	Cleared	Remote creating or modifying Portable Executable, .INI, .PIF, file types, and core system location	
Cleared	Cleared	Running files from common user folders	Trellix-defined
Cleared	Cleared	Running files from common user folders by common programs	Trellix-defined

On-Access Scan

Tab/Area	Field	Value
Show Advanced		
On-Access Scan	Enable On-Access Scan	Selected

General

Tab/Area	Field	Value
	Enable On-Access Scan on system startup	Selected
	Allow users to disable On-Access Scan from the Trellix system tray icon	Cleared
	Specify maximum number of seconds for each file scan	45
	Scan boot sectors	Selected
	Scan processes on service startup and content update	Selected
	Scan trusted installers	Selected
	Scan when copying between local folders	Cleared
	Scan when copying from network folders and removable drives	Cleared
	Detect suspicious email attachments	Cleared
	Disable read/write scan of Shadow Copy volumes for SYSTEM process (improves performance)	Cleared
Trellix GTI	Enable Trellix GTI	Cleared
Antimalware Scan Interface	Enable AMSI (provides enhanced script scanning)	Selected
	Enable Observe mode (Events are generated but actions are not enforced)	Selected
Threat Detection User Messaging	Display the On-Access Scan window to users when a threat is detected	Selected
Message	Trellix Endpoint Security detected a threat. Please contact an Administrator.	
Process Settings	Use Standard settings for all processes	Cleared
	Configure different settings for High Risk and Low Risk processes	Selected
	Process	Process Type
	4nt.exe	High Risk
	agent.exe	High Risk
	aim.exe	High Risk
	aim.exe	High Risk
	bearshare.exe	High Risk
	Cmd.exe	High Risk
	cscript.exe	High Risk
	eudora.exe	High Risk
	Excel.exe	High Risk
	Explorer.exe	High Risk
	FileNavigator.exe	High Risk
	firefox.exe	High Risk
	ftp.exe	High Risk
	gdonkey.exe	High Risk
	gnucleus.exe	High Risk
	ICQ.exe	High Risk
	Iexplore.exe	High Risk
	inetinfo.exe	High Risk
	mirc.exe	High Risk
	mobsync.exe	High Risk
	mosaic.exe	High Risk
	mozilla.exe	High Risk

General

Tab/Area	Field	Value
	MsAccess.exe	High Risk
	MsImn.exe	High Risk
	msmsgs.exe	High Risk
	msn6.exe	High Risk
	neo20.exe	High Risk
	netscape.exe	High Risk
	netscp6.exe	High Risk
	opera.exe	High Risk
	Outlook.exe	High Risk
	PowerPnt.exe	High Risk
	tftp.exeadmin	High Risk
	Visio32.exe	High Risk
	waol.exe	High Risk
	WinPM-32.exe	High Risk
	WinWord.exe	High Risk
	ws_ftp.exe	High Risk
	wscript.exe	High Risk
	wuauclt.exe	Low Risk
	xolox.exe	High Risk
	ypager.exe	High Risk
	yupdate.exe	High Risk
	Aexauditpls.exe	Low Risk
	Aexnsclient.exe	Low Risk
	Aexnsclienttransport.exe	Low Risk
	Aexnswdusr.exe	Low Risk
	icc_cfg.exe,	Low Risk
	iccdrvr.tsk.exe,	Low Risk
	loadall.exe,	Low Risk
	plc_mon.exe	Low Risk
	apiadmin.exe,	Low Risk
	histcfg.exe,	Low Risk
	histmgr.exe,	Low Risk
	histDisp.exe	Low Risk
	IACCSafeguards.exe	Low Risk
	IACC.exe	Low Risk
	FoxSelect.exe	Low Risk
	foxview.exe	Low Risk
	foxdraw.exe	Low Risk
	omset.exe	Low Risk
	omget.exe	Low Risk
	aaIDE.exe	Low Risk
	aaSMC.exe	Low Risk
	aaGR.exe	Low Risk
	aaEngine.exe	Low Risk
	aaBootstrap.exe	Low Risk
	aaClientAccessPoint.exe	Low Risk
	DirectAccess.exe	Low Risk
	view.exe	Low Risk
	aaPim.exe	Low Risk

General

Tab/Area	Field	Value
	Wm.exe	Low Risk
	apisrv.exe	Low Risk
Process Type	Standard	
When to scan	When writing to disk	Cleared
	When reading from disk	Cleared
	Let Trellix decide	Selected
What to scan	All files	Selected
	Default and specified file types	Cleared
	Specified file types only	Cleared
	On network drives	Cleared
	Opened for backups	Cleared
	Compressed archive files	Cleared
	Compressed MIME-encoded files	Cleared
Additional scan options	Detect unwanted programs	Selected
	Detect unknown program threats	Selected
	Detect unknown macro threats	Selected
Actions	Threat detection first response:	Clean files
	If first response fails:	Delete files
	Unwanted program first response:	Clean files
	If first response fails:	Delete files
Exclusions	Exclusion List	
Item	Exclude Subfolders	Read/Write Notes
D:\usr\fox\exten\dcisrvr.exe	No	read / write
D:\usr\fox\exten\fbmload.exe	No	read / write
D:\usr\fox\exten\rls.exe	No	read / write
D:\usr\fox\exten\romload_srvr.exe	No	read / write
D:\usr\fox\sp\files\iom*	No	read / write
D:\usr\fox\exten\om_impdb.dat	No	read / write
D:\Program Files\Invensys\InFusion \FieldDeviceManager\DDBin\	Yes	read / write
C:\Invensys\AIM\	Yes	read / write
D:\Opt\Fox\Ciocfg\	Yes	read / write
D:\Opt\Fox\Ciocfgtemp\	Yes	read / write
D:\Opt\AIM\bin\	Yes	read / write
C:\ProgramData\ArchestrA\	Yes	read / write
C:\Program Files\Common Files \ArchestrA\	Yes	read / write
C:\Program Files\Wonderware\	Yes	read / write
C:\InSQL\Data\	Yes	read / write
C:\Historian\Data\	Yes	read / write
C:\ProgramData\Application Data \ArchestrA\	Yes	read / write
C:\Program Files (x86)\Archestra\	Yes	read / write
C:\Program Files (x86)\Common Files \ArchestrA\	Yes	read / write

General

Tab/Area	Field	Value
C:\Program Files (x86)\Wonderware\	Yes	read / write
D:\Program Files\ArchestrA\	Yes	read / write
D:\Program Files\Wonderware\	Yes	read / write
D:\Program Files\InFusionView\	Yes	read / write
D:\Program Files\FactorySuite\	Yes	read / write
C:\Program Files (x86)\Common Files \Invensys\	Yes	read / write
C:\Program Files (x86)\FactorySuite\	Yes	read / write
C:\Program Files\FactorySuite\	Yes	read / write
C:\Program Files\Veritas\Veritas System Recovery\Console\	Yes	read / write
	Yes	read / write
C:\Historian\	Yes	read / write
C:\Program Files\Dnynsim\	Yes	read / write
C:\Users*\Appdata\Roaming\ArchestrA\ManagedApp	No	read / write
C:\Documents and Settings\All Users\Application Data\Wonderware*.*	Yes	read / write
C:\inetpub\wwwroot\aaflexLicWebService*.*	Yes	read / write
C:\inetpub\wwwroot\AFWeb*.*	Yes	read / write
C:\inetpub\wwwroot\Wonderware*.*	Yes	read / write
C:\Users\All Users\ArchestrA*.*	Yes	read / write
C:\Users\All Users\Wonderware*.*	Yes	read / write
C:\Users\Public\Wonderware*.*	Yes	read / write
C:\Program Files\Wonderware\SuiteVoyager*.*	Yes	read / write
C:\Windows\security\database*.chk	No	read / write
C:\Windows\security\database*.edb	No	read / write
C:\Windows\security\database*.jrs	No	read / write
C:\Windows\security\database*.log	No	read / write
C:\Windows\security\database*.sdb	No	read / write
All files of type v2i	No	read / write
All files of type fbf	No	read / write
All files of type mdf	No	read / write
All files of type ndf	No	read / write
All files of type bak	No	read / write
All files of type trn	No	read / write

General

Tab/Area	Field	Value
C:\ProgramData\ntuser.pol	No	read / write
C:\Windows\System32\GroupPolicy\Machine\Registry.pol	No	read / write
C:\Windows\System32\GroupPolicy\User\Registry.pol	No	read / write
Overwrite exclusions configured on the client		Selected
ScriptScan	Enable ScriptScan	Selected
	Excluded these URLs or partial URLs	NA
Process Type	High Risk	
When to scan	When writing to disk	Cleared
	When reading from disk	Cleared
	Let Trellix decide	Selected
What to scan	All files	Selected
	Default and specified file types	Cleared
	Specified file types only	Cleared
	On network drives	Cleared
	Opened for backups	Cleared
	Compressed archive files	Selected
	Compressed MIME-encoded files	Cleared
Additional scan options	Detect unwanted programs	Selected
	Detect unknown program threats	Selected
	Detect unknown macro threats	Selected
Actions	Threat detection first response:	Clean files
	If first response fails:	Delete files
	Unwanted program first response:	Clean files
	If first response fails:	Clean files
Overwrite exclusions configured on the client		Selected
ScriptScan	Enable ScriptScan	Selected
	Excluded these URLs or partial URLs	NA
Process Type	Low	
When to scan	Do not scan when reading or writing to disk	
What to scan	All files	
	On network drives	Cleared
	Opened for backups	Cleared
	Compressed archive files	Cleared
	Compressed MIME-encoded files	Cleared
Additional scan options	Detect unwanted programs	Cleared
	Detect unknown program threats	Cleared
	Detect unknown macro threats	Cleared
Actions	Threat detection first response:	Clean files
	If first response fails:	Delete files
Exclusions	Exclusion List	
	Item	Exclude Subfolders
	Overwrite exclusions configured on the client	Selected
ScriptScan	Enable ScriptScan	Selected
	Excluded these URLs or partial URLs	NA

General

Exploit Prevention

Tab/Area	Field	Value
Show Advanced		
Exploit Prevention	Enable Exploit Prevention	Cleared
Generic Privilege Escalation Prevention	Enable Generic Privilege Escalation Prevention	Disabled
Windows Data Execution Prevention	Enable Windows Data Execution Prevention	Disabled
Network Intrusion Prevention	Enable Network Intrusion Prevention	Disabled
Exclusion	Exclusion List	NA
	Selection	NA
	Process Name	NA
	Caller Module Name	NA
	API Names	NA
	Notes	NA
	Actions	NA
Signatures	Filter	Disabled
Application Protection Rules	Name	NA
	Status	NA
	Inclusion Status	NA
	Executables	NA
	Changed Notes	NA
	Origin	NA
	Actions	NA

On-Demand Scan

Tab/Area	Field	Value
Show Advanced > Full Scan		
What to Scan	Boot sectors	Selected
	Files that have been migrated to storage	Cleared
	Compressed MIME-encoded files	Cleared
	Compressed archive files	Selected
Additional Scan Options	Detect unwanted programs	Selected
	Detect unknown program threats	Selected
	Detect unknown macro threats	Selected
Scan Locations	Scan subfolders	Selected
	Specify locations	Memory for rootkits
		Running processes
		All local drives
		All removable drives
		All fixed drives
		Registry

General

Tab/Area	Field	Value
File Types to Scan	All files	Selected
	Default and specified file types	Cleared
	Specified file types only	Cleared
Trellix GTI	Enable Trellix GTI	Cleared
Exclusions	Exclusion List	
	Item	Exclude Subfolders
		Read/Write Notes
	Overwrite exclusions configured on the client	Selected
Actions	Threat detection first response:	Clean files
	If first response fails:	Delete files
	Unwanted program first response:	Clean files
	If first response fails:	Delete files
Performance	Use the scan cache	Selected
	System utilization	Below Normal
	Scan Anytime	Cleared
Scheduled Scan Options	Scan only when the system is idle	Selected
	User can resume paused scans	Selected
	Scan anytime	Cleared
	Do not scan when the system is on battery power	Selected
Account	User name:	NA
	Password	NA
	Confirm Password	NA
	Domain	NA
Show Advanced > Quick Scan		
What to Scan	Boot sectors	Selected
	Files that have been migrated to storage	Cleared
	Compressed MIME-encoded files	Cleared
	Compressed archive files	Cleared
Additional Scan Options	Detect unwanted programs	Selected
	Detect unknown program threats	Selected
	Detect unknown macro threats	Selected
Scan Locations	Scan subfolders	Selected
	Specify locations	Running processes
		Registered files
		Windows folder
		Temp folder
File Types to Scan	All files	Selected
	Default and specified file types	Cleared
	Specified file types only	Cleared
Trellix GTI	Enable Trellix GTI	Cleared
	Sensitivity Level:	N/A

General

Tab/Area	Field	Value
Exclusions	Exclusion List	
	Item	Exclude Subfolders
		Read/Write Notes
	Overwrite exclusions configured on the client	Selected
Actions	Threat detection first response:	Clean files
	If first response fails:	Delete files
	Unwanted program first response:	Clean files
	If first response fails:	Delete files
Performance	Use the scan cache	Selected
	System utilization	Below Normal
Scheduled Scan Options	Scan only when the system is idle	Selected
	User can resume paused scans	Selected
	Scan anytime	Cleared
	Do not scan when the system is on battery power	Selected
Account	User name:	N/A
	Password:	N/A
	Confirm password	N/A
	Domain:	N/A
Right-Click Scan		
What to Scan	Boot sectors	Cleared
	Files that have been migrated to storage	Cleared
	Compressed MIME-encoded files	Selected
	Compressed archive files	Selected
	Subfolders	Selected
Additional Scan Options	Detect unwanted programs	Selected
	Detect unknown program threats	Selected
	Detect unknown macro threats	Selected
File Types to Scan	All files	
	Default and specified file types	Cleared
	Specified file types only	Cleared
Trellix GTI	Enable Trellix GTI	Cleared
Exclusions	Item	NA
	Exclude Subfolders	NA
	Read/Write Notes	NA
	Overwrite exclusions configured on the client	Selected
Actions	Threat detection first response:	Clean files
	If first response fails:	Continue scanning
	Unwanted program first response:	Clean files
	If first response fails:	Continue scanning

General

Tab/Area	Field	Value
Performance	Use the scan cache	Selected
	System utilization	Below Normal

Options

Area	Field	Value
Show Advanced		
Quarantine Manager	Quarantine folder:	SYSTEM_ROOT\Quarantine
	Specify the maximum number of days to keep quarantine data:	Selected 30
Exclusion by Detection Name	Detection Name	NA
	Overwrite exclusions configured on the client	Cleared
Potential Unwanted Program Detections	Specify custom potentially unwanted programs to detect. The Description appears as the detection name when a detection occurs.	
	File Name	Description
Proactive Data Analysis	Trellix GTI feedback	Cleared
	AMCore Content Reputation	Cleared

Policy Settings for Solidcore

General Configuration (Client)

Tab	Field	Value
CLI		
Local CLI Access Password	Password	
	Confirm Password	
Local CLI Access Configuration	Enable	Selected
	Disable CLI after	5 failed attempts within 30 minutes
	Disable CLI for	30 minutes
Throttling		
Throttling Settings	Enable Throttling	Selected
	Events	Selected
	Threshold	2000
	Cache Size	7000
	Inventory Updates	Selected
	Threshold	15000
	Policy Discovery	Selected
	Threshold	100
	Cache Size	700
Miscellaneous		
Content Change Tracking Maximum File Size	1000 KB	
Content Change Tracking: File Extensions for attributes-only tracking	.zip, .7z, .rar, .gz, .tgz, .jpg, .gif, .tiff, .png, .bmp, .pdf, .tar, .bz, .bz2, .exe, . dll, .sys, and .jar	
Content Change Tracking:	100	

General

Tab	Field	Value
Maximum file limit per rule		
Inventory Updates: Configuration	Enable on endpoints running version earlier than 6.2.0	Selected
	Enable on endpoints running version 6.2.0 and later	Selected

Policy Settings for Creating Allowlist Application Control Options

Tab/Area	Field	Value
Self-Approval	Enable Self-Approval	Cleared
	Self-Approval Text	NA
	Dialog Timeout	180 SECS
	Justification Message	Disabled
	Advanced Options	Disabled
End User Notifications	User Message	Selected
	Helpdesk Information	Mail to
		Mail Subject
		Link to Website
		Trellix ePO IP Address and Port
	Messages	ActiveX Installation Prevented
		Blocked Interactive Mode of Process
		Execution Denied
		Nx Violation Detected
		Installation Denied
		Prevented File Execution
		Process Hijack Attempted
		File Read Denied
		VASR Violation Detected
		File Write Denied
Features	Enforce Feature Control from Trellix ePO	Selected
	ActiveX	Selected
	Execution Control	Selected
	Memory Protection	Cleared
	CASP	Cleared
	NX (64-Bit)	Cleared
	Generate Observations	Selected
	Package Control #	Selected
	Bypass Package Control:	Cleared
	Allow Uninstallation	Disabled
	Script as Updater	Cleared
Inventory	Hide Windows OS Files	Selected
	Pull Complete Inventory Interval	30 days
	Receive Inventory Updates Interval	4 hours
Reputation	Use Trellix TIE Server	Cleared
	Use Trellix GTI	Cleared
	Reputation-Based Execution	Disabled

General

Tab/Area	Field	Value
	Settings	
	ATD Settings	Disabled

Application Control Rules

Areas	Value
Rule Groups	Add
	My Rules
	.Net Framework
	Adobe Acrobat
	Adobe Acrobat Update
	Default List
	Execution Control Rules
	IIS
	Intel Graphics Driver
	Internet Explorer (32 bit)
	Trellix
	Trellix DLP Agent
	Trellix Exclusion Filters_Schneider
	Trellix Group Shield
	Trellix Publisher
	Observation Filter Rules (Deprecated)
	Office printer HP 2300 Series
	Schneider Electric Application Control Rules
	SE_dnx.exe_policy
	Symantec Backup
	Terminal Server
	USB Plug and Play
	Veritas Backup
	Windows AD Server
	Windows Component
	Windows Server Update Services 2.0 SP1
	Windows Update_Schneider

Schneider Electric Application Control Rules Certificates

Issued To	Issued By	Expiration Date	Friendly Name Updater	Updater Label
Invensys Systems	VeriSign Class 3 Code Signing 2010 CA		Yes	Schneider Electric Cert as Updater
Invensys Systems	VeriSign Class 3 Code Signing 2010 CA		Yes	Schneider Electric Cert as Updater
MKS Software	UTN-USERFirst-Object		No	
MKS Software	UTN-USERFirst-Object		No	
MKS Software	UTN-USERFirst-Object		No	
Microsoft	Microsoft Code Signing PCA		No	

General

Issued To	Issued By	Expiration Date	Friendly Name Updater	Updater Label
Corporation				
Microsoft Corporation	Microsoft Code Signing PCA		No	
Microsoft Corporation	Microsoft Code Signing PCA 2011		No	
Microsoft Corporation	Microsoft Code Signing PCA		No	
Microsoft Corporation	Microsoft Code Signing PCA		No	
Microsoft Corporation	Microsoft Code Signing PCA		No	
Open Text	VeriSign Class 3 Code Signing 2004 CA		No	
Open Text Corporation	VeriSign Class 3 Code Signing 2010 CA		No	
Open Text Corporation	VeriSign Class 3 Code Signing 2010 CA		No	
Open Text Corporation	COMODO RSA Code Signing CA		No	
Oracle America	VeriSign Class 3 Code Signing 2010 CA		No	
P.I. Engineering	GlobalSign CodeSigning CA - SHA256 - G3		No	
PTC Inc.	VeriSign Class 3 Code Signing 2010 CA		No	
PTC Inc.	GlobalSign CodeSigning CA - SHA256 - G2		No	
SafeNet	VeriSign Class 3 Code Signing 2004 CA		No	
Schneider Electric	Symantec Class 3 SHA256 Code Signing CA		Yes	Schneider Electric Cert as Updater
Schneider Electric Software	Symantec Class 3 SHA256 Code Signing CA		Yes	Schneider Electric Cert as Updater
Schneider Electric Software	Symantec Class 3 SHA256 Code Signing CA		Yes	Schneider Electric Cert as Updater
Schneider Electric Software	Symantec Class 3 SHA256 Code Signing CA		Yes	Schneider Electric Cert as Updater

Note: Certificates and Certificates expiry dates shall be update in the FDS As-Built version.

Installers

Installer name	Type	SHA-admin1/SHA-256	Version	Vendor	Installer Label
Microsoft Windows Operating System	SHA-1	3e988fd00d6e95d70c6b3-fa19866377c89fb5359	10	Microsoft	policyDiscovery_AUTO_ TiWorker.exe
Microsoft	SHA-256	e6ca60e5048d5e0310a69fbb-	10	Microsoft	policyDiscovery_AUTO_

General

Installer name	Type	SHA-admin1/SHA-256	Version	Vendor	Installer Label
Windows Operating System		c7eca8051244be788f924-b879ebc3d5a597d7461			TiWorker.exe_sha-256

Users

Type	User-ID/Group	Name	User Label	Include Subgroups
User	DC.DC\IAInstaller	IAInstaller	IAInstaller	NA
User	DC.DC\SE CS Engineer	SE CS Engineer	SE CS Engineer	NA

Executable Files

Rule Name	Allow/Ban	Type	Value
policyDiscovery_AUTO_SRVANY.EXE_sha-256	Allow	File SHA-256	2235a491ed00a61476fb0d-b81457a202ae1f09d5f-d528ac263d9c7602ded1d08
policyDiscovery_AUTO_SRVANY.EXE	Allow	File SHA-1	88be20fba19-ce9462c471f1999410b1c2b511287

Note: Hash values may vary during staging, and updated Hash value will be provided in FDS As-Build.

Trellix Exclusion Filters – Schneider

Exclusion Type	Process Name	Parent Process Name	Library Name
Ignore path for file operations	\Trellix	NA	NA
Exclude path from write-protection rules	\imclntinst	NA	NA
Exclude path from write-protection rules	\lastgood	NA	NA
Skip Change Tracking	\scinv	NA	NA
Exclude path from write-protection rules	\recycled	NA	NA
Exclude path from file operations	\solidcore.log	NA	NA
Ignore path for file operations	\pagefile.sys	NA	NA
Exclude path from write-protection rules	\recycler	NA	NA
Exclude path from write-protection rules	\microsoft\forms	NA	NA
Ignore path for file operations	fbwf.cfg	NA	NA
Skip registry protection	\enum	NA	NA
Skip registry protection	\performance	NA	NA
Exclude path from write-protection rules	\$recycle.bin	NA	NA
Exclude path from write-protection rules	\csc	NA	NA
Ignore path for file operations	\system volume information	NA	NA
Exclude path from write-protection rules	\sis common store	NA	NA
Exclude path from write-protection rules	\qaquotasv4	NA	NA
Exclude path from file operations	\s3diag.log	NA	NA
Ignore path for file operations	\mountpointmanagerre-motedatabase	NA	NA
Exclude path from write-protection rules	\windows\system32	NA	NA
Skip Change Tracking	\scinvlog	NA	NA

General

SE_dnx.exe_Policy Execution Control

Rule Desc.	Action	Process Name	Path	Command Line Argument	Parent Process Name	User Name
NA	Allow	dnx.exe	Equals : d:\program files\wonderware\ historianinsight\ approot\runtimes\d nx-clr-win- x64.1.0.0-rc1- update1\bin	Equals : –project "d:\program files\ wonderware\historiani nsight\ approot\packages\ browserclient\1.0.0\roo t"–configuration release web– server.urls=http://*:325 71/	Equals : cmd.exe	Equals : NT AUTHORITY\NETW ORK SERVICE

Windows Updater Process Schneider

Updater Label	Updater Type	File/SHA-1/SHA- 256	Condition	Parent/Library	Disable Inheritance	Suppress Events
Win_Up_ Start1	Name	svchost.exe	Library	system32\ wuauserv.dll	No	No
Win_Up_ Start11	Name	MRT.exe	None		Yes	No
Win_Up_ Start12	Name	poqexec.exe	None		No	No
RemoteSes- sionInstall1	Name	msiexec.exe	Parent	winlogon.exe	No	No
TrustedInstal- ler1	Name	TrustedInstaller. exe	Parent	services.exe	No	No
DrvInst1	Name	drvinst.exe	Parent	svchost.exe	No	No
Win_Up_ Start13	Name	QueryAppBlock. exe	None		No	No
Win_Up_ Start14	Name	GWXConfigMan- ager.exe	None		No	No
Win_Up_ GdiPlus	Name	System32\LogonUI.exe	None		Yes	No
Win_Up_ Start15	Name	svchost.exe	Library	system32\ wups.dll	No	No
Win_Up_ Start16	Name	svchost.exe	Library	system32\ wups2.dll	No	No
Win_Up_ Start2	Name	svchost.exe	Library	system32\ wuaueng.dll	No	No
Win_Up_ Start17	Name	TiWorker.exe	None		No	No
Win_Up_ Start18	Name	wusa.exe	None		No	No
Win_Up_ Start3	Name	iexplore.exe	Library	wuweb.dll	No	No
Win_Up_ Start19	Name	windowsupdate- box.exe	Parent	setuphost.exe	No	No

General

Updater Label	Updater Type	File/SHA-1/SHA- 256	Condition	Parent/Library	Disable Inheritance	Suppress Events
Win_Up_ Start20	Name	setupplatform.exe	Parent	windeploy.exe	No	No
ONEDRIVE	Name	onedrivestandalo-neupdater.exe	Parent	svchost.exe	No	No
WinUp_ troubleshoot-er	Name	msdt.exe	None		No	No
Win_Up_ Start4	Name	wuauclt.exe	Parent	svchost.exe	No	No
CORTANA	Name	searchUI.exe	Parent	svchost.exe	No	No
Win_Up_ Start5	Name	update.exe	Parent	svchost.exe	No	No

Exclusions

Exclusion Type	Process Name	Parent Process Name	Library Name
Exclude path from the Allowlist	C:\Users*\AppData\Local\Temp*	NA	NA
Ignore path for file operations	\Windows\logs	NA	NA
Exclude path from the Allowlist	C:\Windows\WinSxS\Backup	NA	NA
Exclude path from the Allowlist	C:\Windows\WinSxS\Catalogs	NA	NA
Exclude path from the Allowlist	C:\windows\winsxs\filemaps	NA	NA
Exclude path from the Allowlist	C:\Windows\SoftwareDistribution\Download	NA	NA
Exclude path from the Allowlist	C:\Windows\WinSxS\Temp	NA	NA
Exclude path from the Allowlist	C:\Windows\WinSxS\Manifests	NA	NA
Exclude path from the Allowlist	C:\Windows\SoftwareDistribution\DataStore	NA	NA

General

Policy Settings for Data Loss Prevention Schneider Electric Rule

Tab/Area	Field	Value
DLP Rule Set - Schneider Electric Rule Set		
Removable Storage Protection	Rule Name	Schneider Electric Rule
	Description	Schneider Electric Rule
	State	Enabled
	Severity	Warning
Enforce On:	Trellix DLP Endpoint for Windows	Selected
	Trellix DLP Endpoint for Mac OS X	Cleared
Condition	Classification	is any data (All)
	and End-User	is any user (All)
	and Application copying the file	is any data (All)
and Copy Direction	Outgoing - Copy or Save to removable storage	Selected
	Incoming - Copy to local drive	Selected
and Removable Media	CD and DVD devices (built-in Windows burning feature)	Selected
	Removable Storage devices	Selected
Exception		
Reaction		
Computer connected to corporate network	Action	Block
	User Notification	Default device management user notification
		Close after 5 seconds
Report Incident	Report Incident	Selected
	Store original file as evidence	Selected
Computer disconnected from the corporate network	Action	React the same way as connected system

PNP and Block UAS Devices Rule

Tab/Area	Field	Value
DLP Rule Set - Plug and Play Device Rule		
Removable Storage Device Rule	Rule Name	PNP +BlockUAS Devices
	Description	
	State	Enabled
	Severity	Warning
Enforce On:	Trellix DLP Endpoint for Windows	Selected
	Trellix DLP Endpoint for Mac OS X	Cleared
Condition	and End-User	is any user (All)

General

Tab/Area	Field	Value
	and Plug and Play	is one of (OR)
		UAS
Exception	State	Disabled
	and Plug and Play	is one of (OR)
Reaction		
Computer connected to corporate network	Action	Block
	User Notification	Notification
		Close after 5 seconds
Report Incident	Report Incident	Selected
Computer disconnected from the corporate network	Action	React the same way as connected system
Computer disconnected from the corporate network using VPN	Action	React the same way as connected system

Schneider Electric Removable Storage Device Rule

Tab/Area	Field	Value
DLP Rule Set - Schneider Electric Rule Set		
Removable Storage Device Rule	Rule Name	Schneider Electric Rule Removable Storage Device Rule
	Description	Schneider Electric Rule Removable Storage Device Rule
	State	Enabled
	Severity	Warning
Enforce On:	Trellix DLP Endpoint for Windows	Selected
	Trellix DLP Endpoint for Mac OS X	Cleared
Condition		
	and End-User	is any user (All)
	and Removable Storage	is one of (OR)
		Removable Storage Device
		Removable Storage Device (Windows)
Exception		
Reaction		
Computer connected to corporate network	Action	Block
	User Notification	Default device management user notification
		Close after 5 seconds
Report Incident	Report Incident	Selected
Computer disconnected from the corporate network	Action	React the same way as connected system

General

D

32 Appendix-H Schneider Electric Active Directory Group Policies

General